



PDF Download
3564625.3567985.pdf
11 March 2026
Total Citations: 94
Total Downloads: 1817



Published: 05 December 2022

Citation in BibTeX format

ACSAC: Annual Computer Security
Applications Conference
December 5 - 9, 2022
TX, Austin, USA

 Latest updates: <https://dl.acm.org/doi/10.1145/3564625.3567985>

RESEARCH-ARTICLE

Transformer-Based Language Models for Software Vulnerability Detection

CHANDRA THAPA, Commonwealth Scientific and Industrial Research Organisation, Canberra, ACT, Australia

SEUNG ICK JANG, Commonwealth Scientific and Industrial Research Organisation, Canberra, ACT, Australia

MUHAMMAD EJAZ AHMED, Commonwealth Scientific and Industrial Research Organisation, Canberra, ACT, Australia

SEYIT CAMTEPE, Commonwealth Scientific and Industrial Research Organisation, Canberra, ACT, Australia

JOSEF PIEPRZYK, Polish Academy of Sciences, Warsaw, MA, Poland

SURYA NEPAL, Commonwealth Scientific and Industrial Research Organisation, Canberra, ACT, Australia

Open Access Support provided by:

Commonwealth Scientific and Industrial Research Organisation

Polish Academy of Sciences



Transformer-Based Language Models for Software Vulnerability Detection

Chandra Thapa
CSIRO's Data61
Marsfield, NSW, Australia
chandra.thapa@data61.csiro.au

Seung Ick Jang
CSIRO's Data61
Marsfield, NSW, Australia
seung.jang@data61.csiro.au

Muhammad Ejaz Ahmed
CSIRO's Data61
Marsfield, NSW, Australia
ejaz.ahmed@data61.csiro.au

Seyit Camtepe
CSIRO's Data61
Marsfield, NSW, Australia
seyit.camtepe@data61.csiro.au

Josef Pieprzyk
CSIRO's Data61
Marsfield, NSW, Australia
Institute of Computer Science, Polish
Academy of Sciences
Warsaw, Poland
josef.pieprzyk@data61.csiro.au

Surya Nepal
CSIRO's Data61
Marsfield, NSW, Australia
surya.nepal@data61.csiro.au

ABSTRACT

The large transformer-based language models demonstrate excellent performance in natural language processing. By considering the transferability of the knowledge gained by these models in one domain to other related domains, and the closeness of natural languages to high-level programming languages, such as C/C++, this work studies how to leverage (large) transformer-based language models in detecting software vulnerabilities and how good are these models for vulnerability detection tasks. In this regard, firstly, we present a systematic (cohesive) framework that details source code translation, model preparation, and inference. **Then, we perform an empirical analysis of software vulnerability datasets of C/C++ source codes having multiple vulnerabilities** corresponding to the library function call, pointer usage, array usage, and arithmetic expression. Our empirical results demonstrate the good performance of the language models in vulnerability detection. Moreover, these language models have better performance metrics, such as F1-score, than the contemporary models, namely bidirectional long short term memory and bidirectional gated recurrent unit. Experimenting with the language models is always challenging due to the requirement of computing resources, platforms, libraries, and dependencies. Thus, this paper also analyses the popular platforms to efficiently fine-tune these models and present recommendations while choosing the platforms for our framework.

CCS CONCEPTS

• Security and privacy → Software and application security.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from [permissions@acm.org](https://permissions.acm.org).

ACSAC '22, December 5–9, 2022, Austin, TX, USA

© 2022 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 978-1-4503-9759-9/22/12...\$15.00
<https://doi.org/10.1145/3564625.3567985>

KEYWORDS

Software vulnerability detection, transformer-based models, BERT, GPT-2

ACM Reference Format:

Chandra Thapa, Seung Ick Jang, Muhammad Ejaz Ahmed, Seyit Camtepe, Josef Pieprzyk, and Surya Nepal. 2022. Transformer-Based Language Models for Software Vulnerability Detection. In *Annual Computer Security Applications Conference (ACSAC '22)*, December 5–9, 2022, Austin, TX, USA. ACM, New York, NY, USA, 16 pages. <https://doi.org/10.1145/3564625.3567985>

1 INTRODUCTION

In Natural Language Processing (NLP), transformer-based models outperform existing models, including recurrent neural network (RNN) based architectures [5, 24, 27, 32]. Furthermore, transformer-based language models are attractive and promising over RNN because, unlike RNN, it allows parallelization in the model's computation for faster processing. This is essential to reduce the model training/testing time if the model's size is large, which is a usual case for transformer-based models. Besides, their ability to remodel from natural language processing tasks to related tasks, through the process formally known as *transfer learning*, enables us to extend their usage in other domains. Thus, it is prudent to effectively leverage these models beyond NLP, such as in software vulnerability detection, where most studies are limited to RNN-based models [22, 23].

As software, including operating systems, is an integral part of most computing devices, vulnerability detection at its source-code level is a must-have mechanism for both proprietary and open-source software to ensure protection from adversaries. They can exploit the software vulnerabilities, allowing them not only to control its execution but also to steal or modify its data. For example, a simple buffer overflow bug in software such as NVIDIA SHIELD TV (a popular streaming media device) [38], macOS Catalina (an Apple operating system) [36] and WhatsApp (a popular instant messaging application) [37] could lead to their exploit.

There are additional benefits of transformer-based models in software vulnerability detection. The benefits include the following: (i) it automates the detection that is not possible with the

static analysis tools, which use heuristic methods to find the code constructions from the known vulnerabilities requiring extensive manual operations [40], and (ii) removes the need for extensive feature engineering requirements like in (classical) machine learning.

Although a recent work [44] uses Bidirectional Encoder Representations from Transformers (BERT) [5], a transformer-based language model, in vulnerability detection, it is still unclear how the other models, such as Generative Pre-trained Transformer (GPT) [27] perform. Moreover, training/fine-tuning these models is always challenging due to the requirements such as high computations and huge datasets, specifically arising due to the models' large number of parameters (see Table 3). Thus, this paper aims to answer the following research questions (RQ).

RQ1: How to effectively leverage transformer-based language models for software vulnerability detection? **RQ2:** How well do existing transformer-based language models detect software vulnerabilities compared to other contemporary RNN-based models? **RQ3:** Which platform is efficient for running these models?

In our studies, we choose software source codes written in a high-level programming language, specifically C/C++, because of its popularity [34], and it shares many characteristics with natural languages. Moreover, it inherits natural language grammar [8, 20, 23]. Besides, both have a well-defined structure (or syntax) and contextual meaning (or semantics). Natural languages allow building long sentences from words and shorter phrases. Likewise, programming languages include a collection of instructions to write complex programs. The semantics of natural languages defines the meaning of sentences depending on the order and choice of words and their context. For programming languages, semantics refers to expected actions, their order, and results. Overall, these similarities are additional factors that motivate and enable us to leverage the transformer-based language models in software vulnerability detection efficiently.

Transformer-based language models for software vulnerability detection: By considering (i) transformer-based (large) models of various architectures and sizes, including BERT [5], DistilBERT [31], CodeBERT [8], GPT-2 [27], and Megatron language model variants [32], and (ii) RNN-based models, namely bidirectional long short term memory (BiLSTM) [23], and bidirectional gated recurrent unit (BiGRU) [3], this work contributes to the following:

- **Systematic framework:** To answer **RQ1**, we present a systematic framework for software vulnerability detection based on the existing deep learning frameworks, namely VulDeePecker system [21] and SySeVR framework [22]. Specifically, we use their sliced programs, called code gadgets [21, 22], that extract relevant features from the source codes for vulnerability detection. Besides, the systematic framework details the translation of the source codes to vectorized inputs for the transformer-based models and provides a description of the models, models' preparation, and inference. *To our best knowledge, this is the first work that examines the transformer-based language model on code gadgets.*
- **Comparative performances of the models on software vulnerability detection in C/C++ source code databases:** To answer **RQ2**, firstly, we perform comparative performances analysis under binary and multi-classification tasks to evaluate the models with a vulnerability dataset having *Buffer Error* and *Resource Management Error* [39]. Also, we demonstrate the need for

data cleaning in these tasks. Besides, we provide the fine-tuning time to present an overall time cost of the models. Secondly, we further extend the performance analysis on multiple C/C++ vulnerabilities corresponding to the library function call, pointer usage, array usage, and arithmetic expression that are related to more than 341 Common Weakness Enumeration (CWE) IDs.

- **Platform analysis:** It is always confusing and challenging to handle a large model with billions of model parameters (e.g., GPT-2 with 1.5B parameters). These models can easily exceed the capacity of available Graphics Processing Units (GPU) internal RAM (e.g., 16GB) and usually require parallelisms, such as data parallelism and model parallelism. Finding a suitable platform to fine-tune and test these models effectively is as important as the main problem, i.e., software vulnerability detection. Thus, as an answer to **RQ3**, we provide a platform analysis of four popular platforms, namely Horovod [9], Megatron framework [32], DeepSpeed [25], and HuggingFace [7], along with empirical analysis and our recommendations.

This analysis aids in realizing the framework (**RQ1**) for the transformer-based language models by finding an appropriate platform.

Our systematic framework is publicly available at <https://bitbucket.csiro.au/users/jan087/repos/acsac-2022-submission/browse>.

2 SYSTEMATIC FRAMEWORK

Based on the existing frameworks, including SySeVR, we present a systematic framework for the transformer-based language models for vulnerability detection. In contrast to the existing frameworks, we perform the fine-tuning of the language models rather than their pre-training. These models use different tokenizers (see Table 2), and need special platforms utilizing data parallelism, pipeline parallelism and model parallelism for their computations (refer to Section 4 for details).

2.1 Data translation

The models require formatted data to capture important features related to the vulnerabilities. Moreover, the model, including the transformer-based language model, inputs the vectorized form of the formatted data. Data translation means the conversion of the data (e.g., C/C++ source codes) to an appropriate format, which further transforms into vectorized inputs. In this process, the first step is to change the source code into code gadgets.

2.1.1 Code Gadgets and their extraction. Li et al. [23] propose the code gadgets in software vulnerability. The following describes its generation:

- Load all C/C++ files for analysis of relations between classes.
- Normalize source codes by applying regular expressions. This includes removing comments and non-ASCII characters.
- Extract all function and variable definitions together with their usages.
- Work through all source codes, and if there is a library/API function call, perform a back-track as follows: (1) Extract all variable names from the function call, (2) stack up all lines which have relationships with the variables remaining within the scope of the library/API function, and (3) if any variable passes from a caller, perform another back-track for the caller.

Table 1: Division of VulDeePecker dataset based on its type.

Dataset	Type	Original	Cleaned	Train	Test
Group 1	Buffer Error (BE)	10440	7649	6161	1488
	Non-vulnerable	29313	12262	9768	2494
Group 2	Resource Management Error (RME)	7285	2757	2214	543
	Non-vulnerable	14600	5010	4000	1010
Group 3	BE+ RME	17725	10395	8368	2027
	Combined Non-vulnerable	43913	17197	13704	3491

Overall, each code gadget appears as an assembled semantically related statement slice having data dependency or control dependencies with each other. The gadget associates either with a vulnerability or no vulnerability. In this work, we consider the code gadgets formed based on data dependencies. For an example of a code gadget, refer to Figure 1.

2.1.2 Data preparation. Code gadgets processes through multiple stages before inputting it into the model.

Data cleaning: As the code gadgets extraction involves multiple sources, the dataset can have the following: (i) duplicate code gadgets with the same label and (ii) duplicate code gadgets with different labels (*i.e.*, label conflict). For example, we discover these two issues on the *VulDeePecker dataset* [23] and the Semantics-based Vulnerability Candidate (SeVC) dataset [22] (for more information, refer to Table 1, Table 9 and Appendix A). We call redundant gadgets the duplicate code gadgets with the same label. The VulDeePecker dataset has 32981 redundant gadgets (refer to Table 5 for details). Due to redundant gadgets, the copy of a gadget present in the train set can be present in the test set if we do not check such conditions and perform the train and test split of the dataset based on random sampling, which is a usual way of train/test split. This condition is termed data leakage (to the test set). Moreover, the data leakage contributes to the performance increase on the test set because the model is already trained on the leaked gadgets. Besides, duplicate gadgets with different labels, which we call conflicting gadgets, confuse the algorithms in supervised learning. Thus, these gadgets have a negative impact on model training/testing. Considering the aforementioned issues, we have to clean the dataset. In this regard, firstly, we find the duplicate code gadget by mapping all gadgets into hash values using the SHA256 hashing algorithm provided by the python *hashlib* library. We choose hashing method for finding the duplicates because it is much faster than Regex or naive string comparison methods. For code gadgets with conflicting labels, we remove all such code gadgets, and for same code gadgets with the same labels, we removed their copies from the dataset. Refer to Table 1 for the number of samples in the cleaned and uncleaned (*i.e.*, original) VulDeePecker dataset.

Data pre-processing: Firstly, if there are any comments in the code gadget, we remove them. Secondly, symbolic equivalents replace the user-defined names. This includes replacing (i) user-defined function name by “FUNC” (or using consecutive natural numbers as postfix to “FUNC”, like “FUNC_1” and “FUNC_2”, if multiple functions), and (ii) user assigned variable name by “VAR” (or using consecutive natural numbers as postfix to “VAR”, like “VAR_1” and “VAR_2”, if multiple variables). This way, we normalize the

```
1 CVE-2010-1444/vlc_media_player_1.1.0_CVE-2010-1444_zipstream.c cfunc 449
ZIP_FILENAME_LEN, NULL, 0, NULL, 0 )
char *psz_filename = calloc( ZIP_FILENAME_LEN, 1 );
if( unzGetCurrentFileInfo( file, p_fileInfo, psz_filename,
vlc_array_append( p_filenames, strdup( psz_filename ) );
free( psz_filename );
```

Figure 1: An example of a code gadget of a non-vulnerable library/API function. The first line of the gadget is a header, and the rest is its body.**Table 2: The list of the word embedding methods used for the models considered in this paper. Refer to Huggingface’s site [15] for details on the implementation of these word embedding methods and functions.**

Word Embeddings	Embedding size	Models
Tokenizer (our own) and Word2Vec	512	BiLSTM, BiGRU
Huggingface’s Bert Tokenizer (Tokenize based on WordPiece)	512	BERT (BERTBase, MegatronBERT)
Huggingface’s DistilBert Tokenizer (Runs end-to-end tokenization based on punctuation splitting and WordPiece)	512	DistilBERT
Huggingface’s Roberta Tokenizer (Derived from GPT-2 tokenizer using byte-level Byte-Pair-Encoding)	514	RoBERTa, CodeBERT
Huggingface’s GPT-2 Tokenizer (Based on byte-level Byte-Pair-Encoding)	1024	GPT-2 (GPT-2 Base, GPT-2 Large, GPT-2 XL, MegatronGPT-2), GPT-J
Huggingface’s GPT-2 Tokenizer (Based on byte-level Byte-Pair-Encoding)	2048	GPT-J

code gadget. Thirdly, we create subsets of data based on the available vulnerabilities. For example, we make two sets of data from the VulDeePecker dataset; one with Buffer Error (BE) and its non-vulnerable versions, and the other with Resource Management Error (RME) and its non-vulnerable versions. As we perform both the binary classification and multi-class classification; we assign the labels in the following ways:

- For binary classification labeling, we perform experiments separately for each of the vulnerabilities. For example, BE and RME datasets of the VulDeePecker dataset. If code gadget has vulnerability its label is “1”, and “0” otherwise.
- For multi-class classification labeling, we perform experiments on the union of the vulnerabilities, and we provide the label “0” for the clean data and “1” onward in an increasing order based on the available vulnerability types in the data. For example, the code gadget with BE, RME and non-vulnerable have labels “1”, “2” and “0”, respectively, in VulDeePecker dataset.

Dataset partitioning: Following our data pre-processing step, we divide the dataset into multiple groups for the experiments. For example, we divide the VulDeePecker dataset into three groups; Group 1 with BE and its non-vulnerable code gadgets, Group 2 with RME and its non-vulnerable code gadgets, and Group 3 with combined BE and RME and their non-vulnerable code gadgets. We use the dataset of Group 1 and Group 2 while performing binary classification separately, and use Group 3 while performing three-class classification. The dataset has a train and test set split ratio of 80:20 (*e.g.*, Table 1 shows the number of samples in train and test in the VulDeePecker dataset). We perform three-fold cross-validation and present the overall results for the testing set.

Word embeddings: Word embeddings refer to the learned representation for text data, such as source code, where words map to numeric data vectors in a predefined vector space that encodes the word's meaning. This process mainly has two associated operations: tokenization and embedding. Tokenization converts the input sentence into characters, words, or sub-words, which are semantically-viable segments, and these smaller segments are called tokens. In embedding, these tokens map to relevant vectors using various trained embedding methods, capturing the context around the token in the sentence. In this regard, we use Word2Vec for the BiLSTM and BiGRU models, a WordPiece-based (subword-based) tokenizer for BERT models, and a byte-level Byte-Pair-Encoding based tokenizer for GPT-2 models. Table 2 lists the embedding functions corresponding to the models investigated in this paper.

2.2 Models

Our studies investigate a recurrent neural network-based model and various transformer-based models for vulnerability detection. Table 3 lists these models. We briefly discuss these models in the following (refer to Appendix B for details).

Under recurrent neural networks, we consider BiLSTM [14] and BiGRU [3]. We use BiLSTM and BiGRU models that are close to those used in software vulnerability detection as presented in [23] (the model is not publicly available) and [22], respectively. These models have two issues: (i) they cannot perform well when the input sequence is too long, and (ii) hard to parallelize their operations at sequence level [35]. Transformers remove these shortcomings.

Under transformer-based models, we consider BERT [5], DistilBERT [31], Robustly optimized BERT approach (RoBERTa) [24], CodeBERT [8], GPT-2 [27], and Megatron-Language Model variants [32]. In this paper, we consider the BERT model, called BERT-Base, having 110M parameters with *12 layers, 768 hidden size, and 12 attention heads*. DistilBERT is a smaller, faster, cheaper, and lighter version of BERT, and it has 66M parameters with *6 layers, 768 hidden size, and 12 attention heads*. RoBERTa has the BERTBase architecture, and it pre-trains towards better optimization, performance, and robustness across NLP tasks. CodeBERT is a bimodal pre-trained transformer model for both programming and natural languages. It trains on bimodal data (code & documents) [16], with codes from Python, Java, JavaScript, Ruby, Go, and PHP. Its architecture follows BERT and RoBERTa.

For GPT-based models, their architecture has decoder blocks of transformer and masked self-attention [27]. GPT outperforms available models based on recursive neural networks, convolutional neural networks, and LSTMs [27]. In this paper, we consider GPT-2 models of various sizes: (1) GPT-2 Base, which has 117M parameters with *12 layers, 768 hidden size, and 12 attention heads*, (2) GPT-2 Large, which has 774M parameters with *36 layers, 1280 hidden size, and 20 attention heads*, (3) GPT-2 XL, which has 1.5B parameters with *48 layers, 1600 hidden size, and 25 attention heads*, and (4) GPT-J, which has 6B parameters with *28 layers, 4096 hidden size, and 16 attention heads*, pre-trained on the dataset called Pile having a diverse text data [10].

Megatron-LMs are transformer-based models developed by NVIDIA. Intra-layer model-parallelism on the architecture level of

Table 3: Models considered in our studies and their sizes.

Provider	Language Model	Size	#Parameters
Nvidia	MegatronBERT	Standard	345M
	MegatronGPT-2	Standard	345M
Hugging Face	BERT	Base Model	110M
OpenAI	GPT-2	Base Model	117M
		Large Model	774M
		XL Model	1.5B
EleutherAI	GPT-J	Standard	6B
Hugging Face	DistilBERT	Standard	66M
Microsoft	CodeBERT	Standard	125M
Hugging Face	RoBERTa	Standard	125M
VulDeePecker	BiLSTM	Standard	1.2M
SySeVR	BiGRU	Standard	1.6M

the existing language models, such as BERT and GPT-2 [32], generates Megatron-LMs. In this paper, we consider Megatron versions of BERT and GPT-2 models provided by Nvidia; (1) MegatronBERT having 345M parameters with *24 layers, 1024 hidden size, and 16 attention heads*, and (2) MegatronGPT-2 having 345M parameters with *24 layers, 1024 hidden size, and 16 attention heads*.

2.3 System flow

In this paper, we consider the pre-trained model approach of transfer learning, where we first pick a pre-trained transformer-based model, then a classification head attaches at the top of the final layer of the model, and the resulting model fine-tunes through the software vulnerability dataset consisting of C/C++ source codes. Figure 2 illustrates the overall systematic framework, where the process divides into three main steps: pre-training, fine-tuning, and inference.

2.3.1 Pre-training. In this work, we choose the transformer-based models trained on a large corpus of English texts, except CodeBERT, which trains on source codes of various programming languages. During the pre-training step, the models train in an unsupervised fashion to understand the context of the English words and sentences, including their syntax and semantics.

Except for CodeBERT, all BERT-based models, including RoBERTa, and DistilBERT, pre-train using *masked language modeling* that masked 15% of input token positions randomly, then we predict those masked tokens, and optimize the model based on the original masked tokens and the predicted tokens. Moreover, while training, we replace the masked tokens (1) by token "[MASK]" for 80%, (2) by a random token different than the replaced one for 10%, and (3) by leaving the masked token as it is for 10%.

The models learn a bidirectional representation of the sentence through masked language modeling. On the other hand, the CodeBERT model uses two objectives; masked language modeling for the generator blocks and *replaced token detection* for the discriminator block [8]. The replaced token detection enables the discriminator block to learn effectively about the real and fake output tokens from the generators instead of predicting masked tokens like in masked language modeling. Unlike BERT, GPT-based models, including MegatronGPT-2, use *casual language modeling* objective in which we predict the next word by providing all previous words of an input sentence [28]. Thus, the learning in the GPT model is unidirectional in nature; hence also called an autoregressive model.

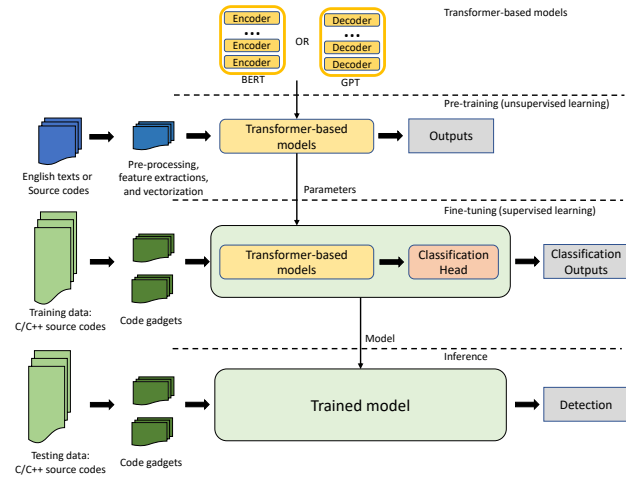


Figure 2: Our systematic framework for software vulnerability detection: pre-training, fine-tuning and inference.

Table 4: Architecture of the classification heads for our models' fine-tuning.

Language Model	Classification Head
BERT, MegatronBERT	Dropout Layer + Linear Layer (size = 3072)
DistilBERT	Linear Layer (size = 3072) + ReLU + Dropout Layer + Linear Layer (size = 3072)
RoBERTa, CodeBERT	Dropout Layer + Linear Layer (size = 3072) + tanh + Dropout Layer + Linear Layer (size = 3072)
GPT-2, MegatronGPT-2	Dropout Layer + Linear Layer (size = 1024)
GPT-J	Linear Layer (size = 2048)

2.3.2 Fine-tuning and inference. Initially, all of our models, except CodeBERT, pre-train on the natural language data. Now they specialize in the software vulnerability detection task, which is a classification task, through fine-tuning. Usually, this requires a small dataset than the pre-training dataset, and carries under supervised learning that requires the knowledge of the data labels. Moreover, this task adds a classification head to the top of the pre-trained model. In this regard, we use the architecture of the classification heads as depicted in Table 4 for the models. For CodeBERT, fine-tuning and inference use only its discriminator block.

For all the transformer-based models in this paper, we allow the entire model architecture to update during the fine-tuning step with a low learning rate. This allows the model's pre-trained weights adjustment based on our software vulnerability dataset (C/C++ source codes). Besides, all the transformer-based models fine-tune for 10 epochs (whereas BiLSTM and BiGRU train for 100 and 20 epochs, respectively, following the existing literature). Then, we test the resulting models on the test dataset in the inference step that results various evaluation metrics, False Positive Rate (FPR) and False Negative Rate (FNR) (refer to Appendix C for details).

3 EXPERIMENTS AND RESULTS

This section presents our empirical results and observations under various experiments. All the transformer-based models in this section are fine-tuned with the training dataset for 10 epochs with

Table 5: Number of samples (code gadgets) having confliction and redundancy in the uncleaned VulDeePecker dataset.

	Confliction	Redundancy	Both Confliction & Redundancy
CWE119 - Buffer	645	18,989	208
CWE399 - Resource	86	13,992	40
Sub-total	731	32,981	248
Merged	741	33,050	257

learning_rate = 1.0e-05, weight_decay = 0.06, and warmup_steps = 500. The weight decay and the warmup steps control the learning rate with the iterations while training. The total number of iterations is calculated as follows:

$$\text{Total iterations} = \frac{\text{Total number of samples} * \text{Training epochs}}{\text{Batch size}}$$

In all our experiments, the batch size equals 16, and a linear learning rate scheduler is used. Now, when we set warmup_steps = 500, and weight_decay = 0.06, then every 500 iterations (steps), our learning rate will be decayed by 6%.

3.1 Need for clean data and testing our BiLSTM

To demonstrate the need for cleaned data empirically, we consider a BiLSTM model as reported by Li et al. [23]. For a fair comparison, we keep the previously reported results and the model, which we call *VulDeePecker Original* model. Considering the VulDeePecker dataset under binary classification, we experiment with our BiLSTM model and BERTBase model on the clean and the original datasets as depicted in Table 1. In binary classification, the model considers only one vulnerability; for other vulnerabilities, the model is trained separately and independently. The BiLSTM model is trained for 100 epochs, and the BERT Base model is fine-tuned for 10 epochs. Our results are depicted in Table 6¹, and they demonstrate the following:

- The results of BiLSTM with the original data are better than with the clean data for both Group 1 and Group 2 datasets. This result confirm a high possibility of data leakage in the test dataset that leads to apparently better test performance. Thus, for fair results, clean data is required for our experiments. We get the same inference from the performance of BERTBase on the Group 2 dataset; however, there are improvements for the Buffer Error.
- The performance of our BiLSTM on original data and VulDeePecker Original is similar for the Group 2 dataset but different for the Group 1 dataset, specifically, FPR and FNR. Although we cannot confirm the closeness of the original and our BiLSTM model, we keep our BiLSTM model and its result for comparison.

3.2 Performance of the transformer-based models on VulDeePecker dataset

In this paper, we perform experiments considering binary and multi-class classifications separately. Moreover, binary classification enables us to know the performance of our models on each specific vulnerability independently. In contrast, multi-class classification

¹These results are average results of three folds of the test sets. Let a test set is represented by T_i , for each fold $i \in \{1, 2, 3\}$. If D represents the clean VulDeePecker dataset, then the corresponding fine-tuning train set is $D \setminus T_i$. The results for BiLSTM are obtained at the end of the 100 epoch, whereas for all other models, it is obtained at the end of the 10 epoch.

Table 6: Test performance of BiLSTM and BERTBase for the binary classification on the original and clean dataset.

Dataset and Vulnerability	Metrics	VulDeePecker Original [23]	BiLSTM (Original Data)	BiLSTM (Clean Data)	BERTBase (Original Data)	BERTBase (Clean Data)
Group 1, Buffer Error	FPR	2.90%	24.99%	33.86%	2.49%	4.05%
	FNR	18.00%	8.46%	15.27%	10.21%	6.52%
	Precision	82.00%	78.57%	71.46%	92.76%	93.56%
	Recall	91.70%	91.54%	84.73%	89.79%	93.48%
Group 2, Resource Management Error	F1-score	86.60%	84.55%	77.50%	91.25%	93.52%
	FPR	2.80%	5.93%	16.10%	1.03%	3.32%
	FNR	4.70%	5.76%	12.63%	3.48%	5.82%
	Precision	95.30%	94.09%	84.50%	97.92%	93.79%
	Recall	94.60%	94.24%	87.37%	96.52%	94.18%
	F1-score	95.00%	94.16%	85.86%	97.21%	93.98%

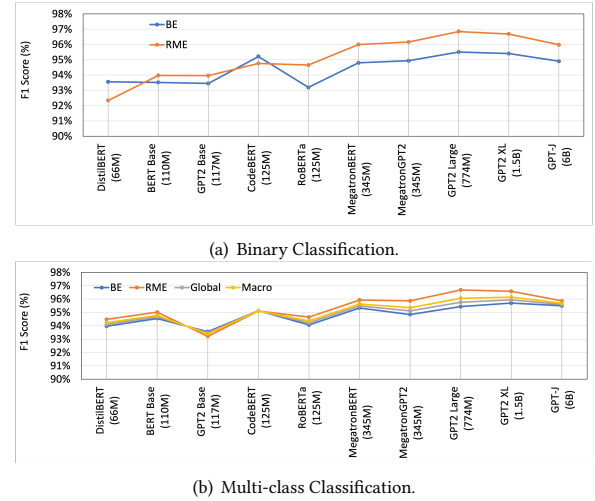
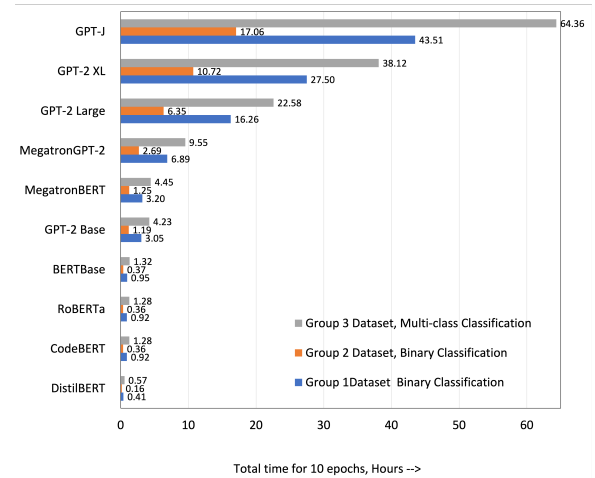
allows us to see the model’s ability to deal with multiple vulnerabilities jointly. In our experiments, we find the differences in the results, and they are presented in the following sections.

3.2.1 Binary classification. The test results for the various models in the binary classification task are presented in Table 7. Separate experiments were performed for Group 1 and Group 2 datasets (see Table 1), and all the models consider two output labels, viz., 0 (non-vulnerable), 1 (vulnerable: BE if Group 1 dataset and RME if Group 2 dataset). We observe an overall improvement in results for the transformer-based models over BiLSTM, including VulDeePecker Original model and BiGRU:

- For Buffer Error, FPR is slightly improved; however, FNR reduction is significant. For example, GPT-2 XL has only 4.72% compared to 18% reported originally for BiLSTM. Besides, improvements in Precision, Recall, and F1-scores are also significant. For example, GPT-2 Large has an F1-score of 95.51% compared to 86.6% reported originally for BiLSTM.
- For Resource Management Error, considering the results reported originally for BiLSTM, GPT-2 Large, GPT-2 XL, MegatronBERT, MegatronGPT-2, and GPT-J models have an improvement in all metrics.

Among transformer-based models, GPT-2 Large and GPT-2 XL show better vulnerability detection. Most interestingly, GPT-J, the largest GPT-2-based model, is not better in detection than its smaller counterparts, such as GPT-2 Large. The possible reason for this is that (1) our dataset size might not be sufficient to fine-tune GPT-J, and (2) GPT-J might need adjustment to its fine-tuning hyperparameters such as learning rate and warm-up steps. We left further exploration in this direction as future work. Now, analyzing the overall trend in the improvements, the performance is in an increasing trend (having some slight fall and rise) with the increase in the model’s size. Refer to Figure 3(a) for an illustration.

3.2.2 Multi-class classification. The test results for the various models in the multi-class classification are presented in Table 8¹. All the experiments were performed using the Group 3 dataset (see Table 1), and all the models consider three output labels, viz., 0 (non-vulnerable), 1 (BE), and 2 (RME). Like in binary classification, we observe an overall improvement in results for the transformer-based models over BiLSTM and BiGRU. Among transformer-based models, considering the global average results, GPT-2 XL shows better Recall and F1-score; whereas GPT-J delivers better precision. Unlike binary classification results, GPT-J, the largest GPT-2-based model considered in this paper, has shown some better results than its smaller counterparts for FPR and Precision. Now, analyzing the overall trend in the improvements, the performance is in an

**Figure 3: The overall trend of F1-score with the increasing size of the Transformer-based models.****Figure 4: Total time is taken in hours to fine-tune our models for 10 epochs using one NVIDIA GPU RTX A6000 with 48GB GDDR6 GPU memory.**

increasing trend (having some slight fall and rise) with the increase in the model’s size. Refer to Figure 3(b) for an illustration.

3.2.3 Fine-tuning time. To give an idea of how long the fine-tuning of these large models will take for the software vulnerability detection, we present the fine-tuning time taken by our models for 10 epochs with binary and multi-classification tasks. We ran our test on our system with NVIDIA GPU RTX A6000 with 48GB GDDR6 GPU memory. All the models were fine-tuned using only one GPU for the time measurement². Our result is depicted in Figure 4. As per expectation for multi-class classification tasks, among our models,

²We fine-tuned all the models with HuggingFace, and we applied DeepSpeed ZeRO Stage 2 on GPT-J only to resolve CUDA Error: out of memory issue.

Table 7: Average test performance¹ of various models for the binary classification on clean VulDeePecker dataset Group 1 and Group 2.

Dataset and Vulnerability	Metrics	VulDeePecker Original [23]	BiLSTM	BiGRU	BERTBase	GPT-2 Base	CodeBERT	DistilBERT	RoBERTa	GPT-2 Large	GPT-2 XL	MegatronBERT	MegatronGPT-2	GPT-J
Group 1, Buffer Error (BE)	FPR	2.90%	33.86%	15.19%	4.05%	4.20%	2.97%	3.85%	4.48%	2.67%	2.66%	3.25%	2.81%	2.74%
	FNR	18.00%	15.27%	35.49%	6.52%	6.44%	4.85%	6.75%	6.56%	4.72%	4.94%	5.24%	5.61%	5.76%
	Precision	82.00%	71.46%	73.04%	93.56%	93.35%	95.27%	93.86%	92.95%	95.74%	95.75%	94.84%	95.49%	95.61%
	Recall	91.70%	84.73%	64.51%	93.48%	93.56%	95.15%	93.25%	93.44%	95.28%	95.06%	94.76%	94.39%	94.24%
	F1-score	86.60%	77.50%	68.37%	93.52%	93.45%	95.21%	93.55%	93.19%	95.51%	95.40%	94.80%	94.94%	94.90%
Group 2, Resource Management Error (RME)	FPR	2.80%	16.10%	4.40%	3.32%	3.81%	3.09%	4.40%	2.92%	1.71%	1.77%	2.40%	2.50%	2.17%
	FNR	4.70%	12.63%	10.34%	5.82%	5.01%	4.71%	7.12%	5.20%	3.10%	3.28%	3.53%	3.03%	3.96%
	Precision	95.30%	84.50%	91.58%	93.79%	92.97%	94.25%	91.82%	94.51%	96.79%	96.66%	95.54%	95.38%	95.96%
	Recall	94.60%	87.37%	89.66%	94.18%	94.99%	95.29%	92.88%	94.80%	96.90%	96.72%	96.47%	96.97%	96.04%
	F1-score	95.00%	85.86%	90.59%	93.98%	93.96%	94.76%	92.34%	94.65%	96.84%	96.69%	96.00%	96.16%	95.98%

Table 8: Average test performance¹ of various models for the multi-class classification on clean VulDeePecker dataset Group 3.

Dataset and Vulnerability	Metrics	BiLSTM	BiGRU	BERTBase	GPT-2 Base	CodeBERT	DistilBERT	RoBERTa	GPT-2 Large	GPT-2 XL	MegatronBERT	MegatronGPT-2	GPT-J
Group 3, Buffer Error (BE)	FPR	21.29%	7.03%	2.37%	2.95%	1.91%	2.42%	2.41%	1.60%	1.47%	1.83%	2.03%	1.44%
	FNR	13.95%	38.64%	4.85%	5.41%	4.83%	5.83%	5.68%	4.96%	4.77%	4.61%	5.08%	5.22%
	Precision	61.00%	78.41%	93.95%	92.55%	95.08%	93.78%	93.82%	95.84%	96.17%	95.28%	94.78%	96.22%
	Recall	86.05%	61.36%	95.15%	94.59%	95.17%	94.17%	94.32%	95.04%	95.23%	95.39%	94.92%	94.78%
	F1-score	71.39%	68.03%	94.55%	93.56%	95.12%	93.97%	94.07%	95.43%	95.70%	95.34%	94.85%	95.49%
Group 3, Resource Management Error (RME)	FPR	3.40%	0.66%	0.66%	1.02%	0.64%	0.73%	0.75%	0.42%	0.42%	0.50%	0.56%	0.25%
	FNR	10.68%	7.49%	4.07%	4.67%	4.12%	4.55%	4.07%	2.85%	3.10%	3.64%	3.27%	5.88%
	Precision	74.48%	93.99%	94.12%	91.20%	94.34%	93.54%	93.40%	96.23%	96.27%	95.52%	95.02%	97.68%
	Recall	89.32%	92.51%	95.93%	95.33%	95.88%	95.45%	95.93%	97.15%	96.90%	96.36%	96.73%	94.12%
	F1-score	81.20%	93.23%	95.02%	93.21%	95.10%	94.48%	94.65%	96.68%	96.58%	95.93%	95.86%	95.87%
Group 3, BE + RME (Global Avg.)	Precision	64.14%	83.08%	93.99%	92.19%	94.88%	93.72%	93.71%	95.94%	96.20%	95.34%	94.83%	96.60%
	Recall	86.92%	69.57%	95.36%	94.79%	95.36%	94.51%	94.74%	95.59%	95.68%	95.65%	95.39%	94.61%
Group 3, BE + RME (Macro Avg.)	Precision	67.74%	86.20%	94.04%	91.88%	94.71%	93.66%	93.61%	96.03%	96.22%	95.40%	94.90%	96.95%
	Recall	87.69%	76.93%	95.54%	94.96%	95.53%	94.81%	95.12%	96.09%	96.07%	95.87%	95.82%	94.45%
	F1-score	76.42%	81.08%	94.78%	93.39%	95.11%	94.23%	94.36%	96.06%	96.15%	95.63%	95.36%	95.68%

GPT-J being the largest model with 6B model parameters, took the highest time, around 65 hours, to run for 10 epochs, and DistilBERT, the smallest model with 66M parameters, took about 35 minutes to run for 10 epochs. Also, we evaluated the models under the test dataset at the end of each epoch in these runs. The pattern is similar for the binary classification tasks with Group 1 and Group 2 datasets. For a model, the fine-tuning time is different for different datasets because of the different sizes of the fine-tuning datasets (see Table 1 where the training dataset is used for fine-tuning these models).

INSIGHT 1. While choosing the model, if there is no time constraint for fine-tuning, then we can pick one of the best performing models, e.g., GPT-2 Large for the Group 1 dataset and F1-score. If there is a time constraint, then we need to pick the model that has the best trade-off between the performance and fine-tuning time, e.g., CodeBERT for Group 1 dataset and F1-score.

3.3 Performance of the transformer-based models on the SeVC dataset

For the studies with more than two vulnerabilities, we consider the Semantics-based Vulnerability Candidate (SeVC) dataset [22] having 126 different vulnerabilities (refer to Appendix A.2 for details). Broadly SeVC is divided into four categories based on the cause of vulnerabilities; API Function Call, Arithmetic Expression, Array Usage, and Pointer Usage. Overall, we divided the dataset into 5 groups for our studies. Refer to Table 9 for details.

Table 9: Division of SeVC dataset based on its categories. The number of vulnerable and non-vulnerable samples are indicated by ‘V’ and ‘NV’, respectively, in the table.

Dataset	Categories	Original	Cleaned	Train	Test
Group 4	API Function Call (AFC)	64403	54181	43344 (V: 10647, NV: 32697)	10837 (V: 2611, NV: 8226)
Group 5	Arithmetic Expression (AE)	22154	14454	11563 (V: 2642, NV: 8921)	2891 (V: 648, NV: 2243)
Group 6	Array Usage (AU)	42229	34166	27332 (V: 8237, NV: 19095)	6834 (V: 2145, NV: 4689)
Group 7	Pointer Usage (PU)	291841	176883	141506 (V: 21189, NV: 120317)	35377 (V: 5335, NV: 30042)
Group 8	AFC + AE + AU + PU	420627	206376	165100 (V: 274804, NV: 145823)	41276 (V: 4769, NV: 36507)

We have performed binary and multi-class classification tasks for the SeVC dataset considering BiLSTM, BiGRU, BERTBase, and GPT-2 Base models. For the binary classification task, BERTBase and GPT-2 Base have an improvement over BiLSTM in all metrics except FPR and Precision for Group 4 and FPR for Group 6 & Group 7. For example, the Group 4 dataset has an F1-score of 90.03% with BERTBase compared to the previously reported results of 86.80% and 78.30% with BiLSTMs. Refer to Table 10 for details. Besides, except for the Group 6 dataset, BiGRU has better FNR compared to other models. There is no result reported in the previous work for multi-class classification tasks, so we compare BERTBase and GPT-2 Base. Considering the global averaged results, BERTBase has performed better than GPT-2 Base. It has 88.34% F1-score. Refer to Table 11 for details. In contrast to binary classification, multi-class classification with SeVC has a low F1-score. This is understandable from the fact that SeVC has multiple vulnerabilities that increase the complexity of machine learning.

Table 10: Test performance of various models for the binary classification on clean SeVC dataset. ‘NA’ refers to ‘Not Available’.

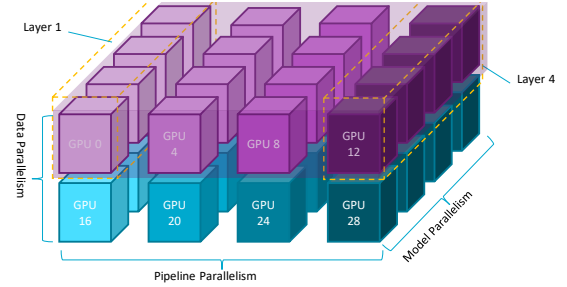
Dataset and Vulnerability	Metrics	VulDeePecker (BiLSTM [22])	SySeVR (BiLSTM [22])	Our BiLSTM	BiGRU	BERTBase	GPT-2 Base
Group 4, API Function Call (AFC)	FPR	5.50%	2.10%	21.08%	15.50%	3.63%	3.28%
	FNR	22.50%	17.50%	8.91%	8.80%	9.06%	11.01%
	Precision	79.10%	91.50%	81.21%	85.47%	89.14%	89.87%
	Recall	77.52%	82.56%	91.09%	91.20%	90.94%	88.99%
	F1- score	78.30%	86.80%	85.87%	88.24%	90.03%	89.43%
Group 5, Arithmetic Expression (AE)	FPR	NA	3.80%	15.43%	18.34%	3.09%	2.32%
	FNR	NA	17.10%	8.30%	6.55%	9.32%	11.21%
	Precision	NA	88.30%	85.60%	83.59%	90.16%	92.28%
	Recall	NA	82.87%	91.70%	93.45%	90.68%	88.79%
	F1- score	NA	85.50%	88.55%	88.25%	90.42%	90.50%
Group 6, Array Usage (AU)	FPR	NA	1.50%	19.73%	18.15%	3.58%	4.32%
	FNR	NA	18.30%	14.26%	13.59%	14.35%	12.24%
	Precision	NA	87.90%	81.29%	82.64%	91.30%	89.92%
	Recall	NA	81.72%	85.74%	86.41%	85.65%	87.76%
	F1- score	NA	84.70%	83.46%	84.49%	88.38%	88.82%
Group 7, Pointer Usage (PU)	FPR	NA	1.30%	15.66%	12.99%	1.40%	1.54%
	FNR	NA	19.70%	5.43%	4.78%	7.96%	8.25%
	Precision	NA	87.30%	85.80%	87.99%	92.02%	91.29%
	Recall	NA	80.39%	94.57%	95.22%	92.04%	91.75%
	F1- score	NA	83.70%	89.97%	91.46%	92.03%	91.52%

Table 11: Test performance of various models for the multi-class classification on clean SeVC dataset.

Dataset and Vulnerability	Metrics	BERTBase	GPT-2 Base
Group 8, API Function Call (AFC)	FPR	0.11%	0.05%
	FNR	25.64%	33.33%
	Precision	83.45%	90.83%
	Recall	74.36%	66.67%
	F1- score	78.64%	76.89%
Group 8, Arithmetic Expression (AE)	FPR	0.21%	0.27%
	FNR	9.96%	9.60%
	Precision	85.40%	81.94%
	Recall	90.04%	90.40%
	F1- score	87.65%	85.96%
Group 8, Array Usage (AU)	FPR	0.39%	0.44%
	FNR	12.44%	11.18%
	Precision	85.16%	83.70%
	Recall	87.56%	88.82%
	F1- score	86.34%	86.19%
Group 8, Pointer Usage (PU)	FPR	0.79%	0.87%
	FNR	9.60%	11.35%
	Precision	89.85%	88.77%
	Recall	90.40%	88.65%
	F1- score	90.12%	88.71%
Group 8, AFC + AE + AU + PU (Global Avg.)	Precision	87.95%	86.88%
	Recall	88.73%	87.47%
	F1 score	88.34%	87.18%
Group 8, AFC + AE + AU + PU (Macro Avg.)	Precision	85.97%	86.31%
	Recall	85.59%	83.63%
	F1 score	85.78%	84.95%

4 PLATFORM ANALYSIS

Handling the transformer-based models requires substantial computational resources. Precisely, a single GPU is not enough to train extra-large models with large-scale data because these models have too many parameters to train, and there are too many samples to process on a single GPU. Thus, usually end up with a “CUDA out of memory” error. For example, in our experiments, we could not run GPT-2 Large with 774M model parameters on an NVIDIA V100 GPU with 16GB internal memory, even with a batch size of 1. In this regard, we consider deep learning parallelism approaches (presented in [27]) to resolve the challenge due to limited GPU memory. For an illustration of the approaches, refer to Figure 5. There are multiple types of parallelism methods that are defined based on how the data and models are computed collaboratively with multiple GPUs. Usually, these methods are collectively called a 3D Parallelism and are described in the following:

**Figure 5: Deep learning model parallelism approaches.**

- **Data parallelism:** Data parallelism splits a large dataset into smaller batches, and each GPU (or GPU group) holds an identical copy of the model parameters. Then, for each batch, each GPU (or GPU group) sends the computed gradients to a parameter server. The parameter server aggregates the computed gradients and calculates the updates. Afterward, it sends the updates to each GPU (or GPU group) for updating.
- **Pipeline parallelism (vertical parallelism):** Pipeline parallelism shares neural network layers into stages with an equal number (desirably) of layers on each stage. Each stage is processed by one GPU (or GPU group), and the calculated output is forwarded to the next stage. For example, splitting a model with 24 layers across 4 stages would mean each stage gets 6 layers. Then, each GPU (or GPU group) processes the assigned stage and passes the output to the following GPU (or GPU group).
- **Model parallelism (tensor parallelism or horizontal parallelism):** Model parallelism splits the execution of a single layer over multiple GPUs, while Pipeline parallelism splits multiple layers across multiple GPUs. Each layer is split up into multiple chunks, and each piece belongs to a designated GPU. The processed results are synced at the end of the step.

4.1 Platforms

To leverage the parallelism while model training/testing in our studies, we have analyzed four popular open-sourced platforms.

Table 12: Summary of popular open-sourced machine learning platforms.

	HuggingFace	Megatron	DeepSpeed	Horovod
Description	A machine learning framework for Jax, Pytorch and TensorFlow	An implementation of Transformer	A deep learning optimization library for distributed training	A python library for data parallelism
Data Parallelism	✓	✓	✓	✓
Pipeline Parallelism	Partial (need customization)	✓	✓	✗
Tensor Parallelism	✗	✓	✓	✗
Memory efficiency	Normal	Normal	Excellent	Normal
Training speed	Normal	Good	Great	Normal
Type	Can use Megatron-LM, and all models	Dedicated only for Megatron-LM	Just a library, supplement tool for memory efficiency and speed	Dedicated only for Data Parallelism

Table 12 summarizes these platforms, and details are presented in the following paragraphs.

Horovod. Horovod [9] is a stand-alone Python library for data parallelism. It uses an optimized ring-all reduce algorithm to improve both performance and usability. It supports TensorFlow, Keras, PyTorch, and Apache MXNet. It can achieve linear performance gain provided that the portion of parameters in the dense layers to all parameters is small [13]. Horovod developers claimed that it achieved 90% scaling efficiency for Inception V3 and ResNet-101 models and 68% scaling efficiency for the VGG-16 model. Model parallelism means models are split and can be evaluated concurrently. With this definition, Horovod supports model partitioning for workload division but does not support model or pipeline parallelism. Without modification of Horovod implementation, it can train only models that fit into a single GPU. Consequently, we do not consider Horovod as a development framework in this work.

Megatron Framework. NVIDIA released Megatron language models and a PyTorch-based framework to train/test the models [32]. The framework and the model support not only model parallelism (pipeline and tensor) but also data parallelism. NVIDIA trained MegatronGPT-2 (8.3 billion parameters) with 8-way model parallelism and 64-way data parallelism, trained on 512 GPUs (NVIDIA Tesla V100) using mixed precision. This is 24× the size of BERT and 5.6× the size of GPT-2 (the previous largest version). MegatronBERT has 3.9 billion parameters, which is 12× the size of the BERTLarge model [27, 28]. As the Megatron framework supports all three parallelism approaches, we utilised it as one of the development frameworks for this work. However, the Megatron framework is model-specific, and hard to utilise other pre-trained models within the framework. So, we only evaluated Megatron BERT 345M model and the GPT-2 345M model by implementing our own model providers, data providers, and metric function provider functions.

DeepSpeed. DeepSpeed [25] is an open-source deep-learning optimization library released by Microsoft for PyTorch. It delivers extreme-scale, extreme memory efficient, and extremely communication efficient model training by leveraging model parallelism on existing computer resources. DeepSpeed introduces Zero Redundancy Optimizer (ZeRO), and it enables 10× larger models, 10× faster training, and minimal code change. As a specific example, the memory consumption for training a 7.5B parameter model is about 120GB of GPU RAM (the calculation is based on 64 GPUs). The ZeRO Stage 1 partitions optimizer states across the GPUs and requires 31.4GB of GPU RAM (the calculation is based on 64 GPUs). The ZeRO Stage 2 reduces 32-bit gradients to 16-bit for updating

the model weights, and it requires 16.6GB of GPU RAM. In ZeRO Stage 3, the 16-bit model parameters are partitioned across the GPU, and it requires only 1.9GB of GPU RAM. Recently DeepSpeed introduced ZeRO-Infinity, which leverages the total memory capacity of a system, concurrently exploiting all heterogeneous memory (GPU, CPU, and NVMe). They claimed that with a single NVIDIA DGX-2 node, a 1000 billion parameter model could be trained. The key idea of ZeRO-Infinity is offloading data into other types of memory. It splits a model into multiple states and stores into CPU or NVMe device memory, which are usually much bigger than GPU memory, and GPU holds only a small portion of states for computing. We have used DeepSpeed in this work due to its above features.

HuggingFace. HuggingFace [7] supports only data parallelism but did not officially implement model parallelism (neither pipeline nor tensor). However, HuggingFace integrates DeepSpeed, enabling users to enjoy the benefits of DeepSpeed, such as ZeRO stages. There are two options to integrate DeepSpeed: (1) Integration of the core DeepSpeed features via Trainer: Users need to use Trainer and supply the DeepSpeed config file. The rest of the things will be done automatically. We strongly recommend this integration method. (2) Integrate DeepSpeed by ourself: Core functionality functions must be implemented, such as `from_pretrained` and `from_config`.

4.2 Discussion on the platforms

In this section, firstly, we present the challenges that we faced, then provide our recommendations.

4.2.1 Challenges. (1) No admin privilege: Institutions have HPC clusters that consist of multiple nodes. For example, we have an HPC cluster with 114 nodes. Each node has two Xeon 14-core E5-2690 v4 CPUs and four NVIDIA Tesla P100 16 gigabytes GPUs. Due to security and maintenance reasons, the service owner does not provide admin privilege to HPC users, and this policy has created many issues. For instance, we cannot install system-dependent programs/libraries by ourselves, and due to the version of HPC OS (SUSE Linux 12.4), we could not use the latest versions of NVIDIA drivers and CUDA. We have used Anaconda [?] to set up virtual environments, and within the virtual environments, we installed pre-requisites and dependencies, which were not supported by the HPC environment directly (in non-virtual environments).

(2) Model Parallelism: Some models in the HuggingFace framework support a naive pipeline model parallelism, such as GPT-2 and T5. Users need to define a dictionary that maps attention layers to GPUs, and the embedding layer and LMHead are always automatically mapped to the first device. This is an experimental feature and has some GPU idling problems (it is hard to balance workload between GPUs). Megatron supports tensor model parallelism and pipeline model parallelism. However, NVIDIA does not provide parallelised pre-trained models, and users need to write a program to split/merge Megatron-LM models for model parallelism.

(3) Small GPU RAM: Many internal users share the HPC cluster in an institution, and acquiring GPU computing resources is very competitive. Moreover, each GPU can have less RAM size. For example, our has only 16 gigabyte GPU RAM. These restrictions created issues, especially when we fine-tuned the large models. For instance, to fine-tune the GPT-2 Extra Large model for the dataset,

Table 13: Fine-tuning performance comparison results of GPT-2 XL model with/without DeepSpeed.

Model	GPT-2 XL	GPT-2 XL	GPT-2 XL	GPT-2 XL
Number of GPU	1	2	1	2
Applied DeepSpeed	No	No	Stage 2	Stage 2
Parallelization	-	Data	-	Data
Epoch	2	2	2	2
Batch Size / GPU	16	16	16	16
Train Samples	22072	22072	22072	22072
Train Runtime	7H:38M:06S	3H:52M:09S	5H:38M:46S	3H:23M:16S
Train Runtime / epoch	3H:49M:03S	1H:56M:05S	2H:49M:23S	1H:41M:38S
Train Samples / second	1.606	3.169	2.172	3.620
Train Samples / second / GPU	1.606	1.584	2.172	1.810
Train Runtime for 1 sample	0.623	0.631	0.460	0.553
Multi-GPU overhead	-	1.36%	-	20.00%
Average GPU RAM usage (MB, batch size: 1)	29633	35755	12515	12285
DeepSpeed Runtime Gain	-	-	26.05%	12.45%
DeepSpeed Memory Gain	-	-	57.77%	65.64%

we used 4 GPUs with the HuggingFace pipeline model parallelism. Due to the overhead of parallelism and the GPU idling problems, the fine-tuning task required a long processing time.

4.2.2 Our recommendations. As a machine learning framework, HuggingFace provides thousands of pre-trained models to perform various tasks on text, image, and sound. The framework provides not only easy-to-use APIs but also affordable memory efficiency and training speed. However, it supports only data parallelism and is very hard to train large models due to the lack of model parallelism supports. Megatron framework can be an alternative platform to perform tasks with large models as it supports 3D parallelism. Nevertheless, the Megatron framework only provides a limited number of pre-trained language models. Besides, the DeepSpeed framework supports 3D parallelism with very high memory efficiency and high training speed. Moreover, it can be easily integrated with HuggingFace models. We applied DeepSpeed ZeRO Stage 2 on HuggingFace models to resolve our engineering challenges. With a single 16GB RAM GPU, we could fine-tune the GPT-2 XL model. Even though it was not practical, we could barely fine-tune the GPT-J model, consisting of 6 billion parameters, only with a single GPU.

We evaluated the training performance of the DeepSpeed framework in terms of processing speed and memory efficiency. We ran our test on our system with two RTX A6000 48GB GPUs, and the performance comparison results are depicted in Table 13. When we were fine-tuning the GPT-2 XL model with a single GPU, the average train runtime per epoch was 3H : 49M : 03S without DeepSpeed. But with DeepSpeed, the average train runtime per epoch was 2H : 49M : 23S, 26.05% of the performance gain. More interestingly, when we applied DeepSpeed on the fine-tuning task, GPU RAM usage was cut by 57.77%, making a large model fit into a small GPU RAM. Similarly, we could get 12.45% processing speed gain and 65.64% memory gain from the 2-GPU comparison.

INSIGHT 2. We summarize our recommendations in the following: (1) Stick with data parallelism if the model fits inside one GPU, and (2) if we could not accommodate the model inside one GPU, go with Huggingface and DeepSpeed frameworks.

5 RELATED WORK

To automate the generation of program documents and facilitate the natural language code search, a transformer-based language model, called CodeBERT [8], is trained on pairs of natural languages and programming languages; for example, a source code slice having few comments in natural language regarding program description followed by the code instructions. CodeBERT’s architecture consists of a BERT model and two generators, one for code instructions and the other for the natural language description. CodeBERT has a few variants, such as (i) GraphCodeBERT [12] that uses semantic-level data flow structure, (ii) BART [18], with both encoder and decoder part in its model architecture, and its extension (iii) PLBART [1]. In our work, we consider only CodeBERT because it is a base model and not investigate its usage in software vulnerability detection.

A BERTBase model is used for software vulnerability detection [44]. It was fine-tuned with Software Assurance Reference Dataset (SARD) database of 100K C/C++ source files and tested with 123 vulnerabilities. This work showed that the BERTBase model and BERT with RNN heads of LSTM or BiLSTM models outperform standard LSTM or BiLSTM models. The highest detection accuracy reported was 93.49% for their dataset and model. In contrast to this work, we consider a large dataset and multiple model architectures like GPT-2 and MegatronBERT [32]. Besides, the data input form is different; they used the source file after removing labels and comments, whereas we leverage code gadgets.

Typically, software vulnerability detection has been investigated through (i) dynamic analysis, (ii) pattern matching, and (iii) machine learning with Convolutional Neural Networks (CNN) and Recurrent Neural Networks (RNN)-based models. Dynamic analysis executes a program looking for unusual or unexpected behavior. Fuzzing [33] (or Atheris [11] for python codes) and the taint analysis [26] are good examples of dynamic techniques. Unfortunately, they are not efficient for a long code/program as their runtime increases exponentially with the code/program length. On the pattern matching side, (i) code similarity techniques, (ii) rule-based techniques, and (iii) code-property graphs are used. Code-similarity techniques find vulnerabilities by comparing a currently scanned code with signatures of identified vulnerable codes. Those signatures are created by hashing, selection of substrings, or abstract representation such as graphs and trees. VUDDY [17] and Vulpecker [21] are examples of code-similarity techniques. For the rule-based technique, the analyst decides on rules that identify vulnerabilities. Flawfinder [40] and Coverity [4] apply the rule-based method. Unfortunately, both code-similarity and rule-based techniques produce either high false negatives or high false positives, or both. This is due to the fact that the decision about vulnerability depends solely on historical data. Consequently, new unseen vulnerabilities cannot be detected. Vulnerability detection works in two steps for code-property graph techniques: First, for a given source code, an appropriate graph is constructed by combining its abstract syntax tree and program dependence graph. Then, the code-property graph is traversed to detect vulnerabilities [41]. Sadly, this technique still requires human intervention and supervision.

Machine learning automates the detection and learning process with limited or no human intervention. However, classical machine learning requires feature engineering, which is difficult, extensively

laborious, error-prone, and also needs human help to some extent. Thus, a significant body of research has studied deep learning but is limited to CNN and RNN-based models [19, 23, 30]. As these models require formatted data to capture important features related to the vulnerabilities, methods such as the lexed representation of C/C++ code [30], code gadget [23], code-property graphs [6], improved code gadget with code attention and system dependency graph [45], and a minimum intermediate representation learning [19] are proposed. Besides deep learning language models, some works have been done using graph neural networks in software vulnerability detection [42]. The method is named Devign, and it captures composite programming representations (abstract syntax tree, control flow, and data flow) of source codes. Overall, all these methods improve one over the other, but still, the results can be improved.

6 LIMITATIONS

This work is a step toward finding an efficient solution to vulnerability detection. There are several places for improvement despite the presented framework and results that motivate further investigations. **Firstly, we consider the vulnerabilities related to C/C++ source codes.** Precisely, we draw the results and insights from VulDeePecker and SeVC datasets. This limits the results and drawn conclusions to the datasets. So, for generalizability, more studies are required considering other (large) datasets. Besides, investigations of the performance of transformer-based language models in other popular programming languages, such as Python, Java and Javascript, are still open. **Secondly**, this work focuses on the standard code gadget and its extraction rather than its improved versions to see the relevance of the approach with the transformer-based language models. Moreover, any improved versions of extraction techniques for the code representation can be easily transferred to our work by updating the code gadget. Thus, we do not use minimum intermediate representation learning and graph neural networks. However, in most cases, our results with transformer-based models and standard code gadgets are better than those with minimum intermediate representation (see Section 3). We cannot compare our results with graph neural network results due to their results in different datasets. These tasks are important directions to be considered in future works. **Thirdly**, as transformer-based language models have a huge number of parameters to train, usually increasing the fine-tuning dataset size enables improvements in the model's performance. However, this requires new data collection and investigation, thus left as future work. Moreover, the investigation of the effect of other factors, including the choice of the model's classification head (in this paper, we have used the standard available classification heads of the models) and hyper-parameter tuning, on the overall performance improvements are left open.

7 CONCLUSION

This paper studied transformer-based language models for software vulnerability detection. Firstly, it presented a systematic framework to use these models in the domain. As a part of the framework, popular platforms to run these language models were analyzed. Secondly, it presented the comparative performances of these models along with recurrent neural network (RNN)-based models under

binary and multi-class classification tasks. For the dataset with two vulnerabilities, buffer and resource management errors, related to the API function call, the transformer-based language models outperformed BiLSTM and BiGRU in all performance metrics (e.g., FPR, FNR, and F1-score). More precisely, GPT-2 Large and GPT-2 XL have the best F1-score for binary and multi-class classification (global average), respectively. The overall trend for F1-score was increasing with the models' increasing size. For a separate dataset with 126 types of different vulnerabilities (related to 341 CWE IDs) falling under four broad categories – API function call, pointer usage, array usage, and arithmetic expressions – this paper studied the performance of BiLSTM, BiGRU, BERTBase, and GPT-2 Base. Our results in binary classification tasks demonstrated that BERT-Base and GPT-2 have better F1-score, but not good than BiGRU in FNR except for the array usage category. Overall, the transformer-based language models performed well in vulnerability detection in C/C++ source codes.

ACKNOWLEDGMENTS

This material is based upon work supported by the US Army International Technology Center Indo-Pacific (ITC-IPAC) under Contract No. FA520921P0015. Any opinions, findings and conclusions, or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the U.S. Army ITC-IPAC. Besides, we acknowledge our vacation student Mr. Andrew Cain for his help during the preliminary stage of this work. The work of Josef Pieprzyk was supported in part by Polish National Science Center (NCN) under Grant 2018/31/B/ST6/03003.

REFERENCES

- [1] Wasi Uddin Ahmad, Saikat Chakraborty, Baishakhi Ray, and Kai-Wei Chang. 2021. Unified Pre-training for Program Understanding and Generation. *CoRR abs/2103.06333* (2021). arXiv:2103.06333 <https://arxiv.org/abs/2103.06333>
- [2] Janacoda Anaconda. [n. d.]. Anaconda. <https://www.anaconda.com>
- [3] Kyunghyun Cho, Bart van Merriënboer, Caglar Gulcehre, Dzmitry Bahdanau, Fethi Bougares, Holger Schwenk, and Yoshua Bengio. 2014. Learning Phrase Representations using RNN Encoder-Decoder for Statistical Machine Translation. (2014). <https://doi.org/10.48550/ARXIV.1406.1078>
- [4] Coverity. 2022. Coverity. <https://scan.coverity.com/>
- [5] Jacob Devlin, Ming-Wei Chang, Kenton Lee, and Kristina Toutanova. 2019. BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding. In *Proc. the 2019 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies, NAACL-HLT*. 4171–4186. <https://doi.org/10.18653/v1/n19-1423>
- [6] Xu Duan, Jingzheng Wu, Shouling Ji, Zhiqing Rui, Tianyue Luo, Mutian Yang, and Yanjun Wu. 2019. VulSniper: Focus Your Attention to Shoot Fine-Grained Vulnerabilities. In *Proceedings of the 28th International Joint Conference on Artificial Intelligence (Macao, China) (IJCAI'19)*. AAAI Press, 4665–4671.
- [7] Hugging Face. 2022. Transformers: State-of-the-art Machine Learning for JAX, PyTorch and TensorFlow. <https://huggingface.co/docs/transformers/index>
- [8] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Proc. of Findings of the Association for Computational Linguistics: EMNLP 2020*. 1536–1547. <https://doi.org/10.18653/v1/2020.findings-emnlp.139>
- [9] The Linux Foundation. 2022. Horovod. <https://horovod.ai>
- [10] Leo Gao, Stella Biderman, Sid Black, Laurence Golding, Travis Hoppe, Charles Foster, Jason Phang, Horace He, Anish Thite, Noa Nabeshima, Shawn Presser, and Connor Leahy. 2020. The Pile: An 800GB Dataset of Diverse Text for Language Modeling. *arXiv preprint arXiv:2101.00027* (2020).
- [11] Google. 2020. Atheris. <https://pythip.org/project/atheris/>
- [12] Daya Guo, Shuo Ren, Shuai Lu, Zhangyin Feng, Duyu Tang, Shujie Liu, Long Zhou, Nan Duan, Alexey Svyatkovskiy, Shengyu Fu, Michele Tufano, Shao Kun Deng, Colin B. Clement, Dawn Drain, Neel Sundaresan, Jian Yin, Daxin Jiang, and Ming Zhou. 2020. GraphCodeBERT: Pre-training Code Representations with Data Flow. *CoRR abs/2009.08366* (2020). arXiv:2009.08366 <https://arxiv.org/abs/2009.08366>

- [13] B. Hasheminezhad, S. Shirzad, N. Wu, P. Diehl, H. Schulz, and H. Kaiser. 2020. Towards a Scalable and Distributed Infrastructure for Deep Learning Applications. In *2020 IEEE/ACM Fifth Workshop on Deep Learning on Supercomputers (DLS)*. IEEE Computer Society, Los Alamitos, CA, USA, 20–30. <https://doi.org/10.1109/DLS51937.2020.00008>
- [14] Sepp Hochreiter and Jürgen Schmidhuber. 1997. Long short-term memory. *Neural Computation* 9, 8 (1997), 1735–1780. <https://direct.mit.edu/neco/article-abstract/9/8/1735/6109/Long-Short-Term-Memory?redirectedFrom=fulltext>
- [15] Huggingface.co. 2020. Tokenizer summary. https://huggingface.co/transformers/v3.0.2/tokenizer_summary.html
- [16] Hamel Husain, Ho-Hsiang Wu, Tiferet Gazit, Miltiadis Allamanis, and Marc Brockschmidt. 2019. CodeSearchNet Challenge: Evaluating the State of Semantic Code Search. *CoRR abs/1909.09436* (2019). arXiv:1909.09436 <http://arxiv.org/abs/1909.09436>
- [17] Seulbae Kim, Seunghoon Woo, Heejo Lee, and Hakjoo Oh. 2017. VUDDY: A Scalable Approach for Vulnerable Code Clone Discovery. In *2017 IEEE Symposium on Security and Privacy (SP)*. 595–614. <https://doi.org/10.1109/SP.2017.62>
- [18] Mike Lewis, Yinhan Liu, Naman Goyal, Marjan Ghazvininejad, Abdelrahman Mohamed, Omer Levy, Veselin Stoyanov, and Luke Zettlemoyer. 2019. BART: Denoising Sequence-to-Sequence Pre-training for Natural Language Generation, Translation, and Comprehension. *CoRR abs/1910.13461* (2019). arXiv:1910.13461 <http://arxiv.org/abs/1910.13461>
- [19] Xin Li, Lu Wang, Yang Xin, Yixian Yang, and Yuling Chen. 2020. Automated Vulnerability Detection in Source Code Using Minimum Intermediate Representation Learning. *Applied Sciences* 10, 5 (2020). <https://doi.org/10.3390/app10051692>
- [20] Zhen Li, Deqing Zou, Shouhuai Xu, Zhaoxuan Chen, Yawei Zhu, and Hai Jin. 2021. VulDeeLocator: A Deep Learning-based Fine-grained Vulnerability Detector. *IEEE Transactions on Dependable and Secure Computing* (2021), 1–1. <https://doi.org/10.1109/TDSC.2021.3076142>
- [21] Zhen Li, Deqing Zou, Shouhuai Xu, Hai Jin, Hanchao Qi, and Jie Hu. 2016. VulPecker: an automated vulnerability detection system based on code similarity analysis. In *Proc. of the 32nd Annual Conference on Computer Security Applications*. 201–213. <https://doi.org/10.1145/2991079.2991102>
- [22] Zhen Li, Deqing Zou, Shouhuai Xu, Hai Jin, Yawei Zhu, and Zhaoxuan Chen. 2021. SySeVR: A framework for using deep learning to detect software vulnerabilities. *IEEE Trans. Dependable Sec. Comput* (2021). <https://doi.org/abs/1807.06756>
- [23] Zhen Li, Deqing Zou, Shouhuai Xu, Xinyu Ou, Hai Jin, Sujuan Wang, Zhijun Deng, and Yuyi Zhong. 2018. VulDeePecker: A Deep Learning-Based System for Vulnerability Detection. In *Proc. Network and Distributed System Security Symposium (NDSS)*. Internet Society. <https://doi.org/10.14722/ndss.2018.23158>
- [24] Yinhan Liu, Mylène Ott, Naman Goyal, Jingfei Du, Mandar Joshi, Danqi Chen, Omer Levy, Mike Lewis, Luke Zettlemoyer, and Veselin Stoyanov. 2019. RoBERTa: A Robustly Optimized BERT Pretraining Approach. *CoRR abs/1907.11692* (2019). arXiv:1907.11692 <http://arxiv.org/abs/1907.11692>
- [25] Microsoft. 2022. DeepSpeed. <https://www.deepspeed.ai>
- [26] James Newsome and Dawn Song. 2005. Dynamic Taint Analysis for Automatic Detection, Analysis, and Signature Generation of Exploits on Commodity Software. In *Proc. NDSS*.
- [27] Alec Radford, Karthik Narasimhan, Tim Salimans, and Ilya Sutskever. 2018. Improving Language Understanding by Generative Pre-Training. https://cdn.openai.com/research-covers/language-unsupervised/language_understanding_paper.pdf
- [28] Alec Radford, Jeff Wu, Rewon Child, David Luan, Dario Amodei, and Ilya Sutskever. 2019. Language Models are Unsupervised Multitask Learners. (2019). https://cdn.openai.com/better-language-models/language_models_are_unsupervised_multitask_learners.pdf
- [29] Anna Rogers, Olga Kovaleva, and Anna Rumshisky. 2020. A Primer in BERTology: What We Know About How BERT Works. *Trans. of the Association for Computational Linguistics* 8 (2020), 842–866. https://doi.org/10.1162/tacl_a_00349
- [30] Rebecca L. Russell, Louis Kim, Lei H. Hamilton, Tomo Lazovich, Jacob A. Harer, Onur Ozdemir, Paul M. Ellingwood, and Marc W. McConley. 2018. Automated Vulnerability Detection in Source Code Using Deep Representation Learning. In *Proc. ICMLA*. 757–762.
- [31] Victor Sanh, Lysandre Debut, Julien Chaumond, and Thomas Wolf. 2019. DistilBERT, a distilled version of BERT: smaller, faster, cheaper and lighter. In *Proc. EMNLP: 5th Edition Co-located with NeurIPS'19*. 1–5.
- [32] Mohammad Shoyebi, Mostafa Patwary, Raul Puri, Patrick LeGresley, Jared Casper, and Bryan Catanzaro. 2020. Megatron-LM: Training Multi-Billion Parameter Language Models Using Model Parallelism. arXiv:1909.08053 [cs.CL]
- [33] Michael Sutton, Adam Greene, and Pedram Amini. 2007. Fuzzing: Brute Force Vulnerability Discovery. *Pearson Education* (2007).
- [34] the software quality company TIOBE. 2022. TIOBE Index for May 2022. <https://www.tiobe.com/tiobe-index/>
- [35] Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N Gomez, Łukasz Kaiser, and Illia Polosukhin. 2017. Attention is all you need. In *Proc. Advances in neural information processing systems*, Vol. 30. Curran Associates, Inc., 5998–6008.
- [36] VULDB. 2020. Apple macOS USD File buffer overflow. <https://vuldb.com/?id.163591>
- [37] VULDB. 2020. Facebook WhatsApp on Android Video Stream buffer overflow. <https://vuldb.com/?id.160672>
- [38] VULDB. 2021. NVIDIA Shield TV up to 8.2.1 NVDEC buffer overflow. <https://vuldb.com/?id.168508>
- [39] VulDeePecker. 2018. Database of "VulDeePecker A Deep Learning-Based System for Vulnerability Detection". <https://github.com/CGCL-codes/VulDeePecker>
- [40] David A. Wheeler. 2018. Flawfinder. <https://dwwheeler.com/flawfinder/>
- [41] Fabian Yamaguchi, Nico Golde, Daniel Arp, and Konrad Rieck. 2014. Modeling and discovering vulnerabilities with code property graphs. In *Proc. IEEE Symposium on Security and Privacy*. 590–604.
- [42] Yaqin Zhou, Shangqing Liu, Jingkai Siow, Xiaoning Du, and Yang Liu. 2019. Devign: Effective Vulnerability Identification by Learning Comprehensive Program Semantics via Graph Neural Networks. In *Proc. NeurIPS*.
- [43] Yukun Zhu, Ryan Kiros, Richard S. Zemel, Ruslan Salakhutdinov, Raquel Urtasun, Antonio Torralba, and Sanja Fidler. 2015. Aligning Books and Movies: Towards Story-like Visual Explanations by Watching Movies and Reading Books. *CoRR abs/1506.06724* (2015). arXiv:1506.06724 <http://arxiv.org/abs/1506.06724>
- [44] Noah Ziem and Shaoyan Wu. 2021. Security Vulnerability Detection Using Deep Learning Natural Language Processing. arXiv:2105.02388 [cs.CR]
- [45] Deqing Zou, Sujuan Wang, Shouhuai Xu, Zhen Li, and Hai Jin. 2019. μVulDeePecker: A deep learning-based system for multiclass vulnerability detection. *IEEE Trans. Dependable Sec. Comput* (2019). <https://doi.org/10.1109/TDSC.2019.2942930>

A DATASETS

A.1 VulDeePecker Data

We consider the dataset published by CGCL/SCTS/BDTS Lab1 of Huazhong University of Science and Technology [39]. We call this dataset *VulDeePecker dataset* because it was released as a part of their work that proposed a deep learning-based system for vulnerability detection called VulDeePecker [23]. The dataset contains two common types of vulnerabilities collected from (i) syntactic and academic security flaws and (ii) popular open-source projects, including Linux kernel, Thunderbird, Wireshark, Apache HTTP Server, Xen, OpenSSL, and VLC media player, mostly available on the National Vulnerability Database (NVD) and the NIST Software Assurance Reference Dataset (SARD). The vulnerabilities are the following:

- **CWE-119 Buffer Error (BE):** BE covers buffer vulnerabilities caused by direct addressing of memory location without proper validation of a referenced memory buffer. Refer to Figure 6 for an example.
- **CWE-399 Resource Management Error (RME):** RME includes resource management vulnerabilities induced by improper handling of resources, which may lead to a variety of errors such as resource exhaustion, memory leakage, channel, and path exceptions. Refer to Figure 7 for an example.

A.2 SeVC Data

We consider the Semantics-based Vulnerability Candidate (SeVC) dataset having 126 types of different vulnerabilities [22]. This dataset is collected from 1591 open-source C/C++ programs from the National Vulnerability Database (NVD) and 14000 programs from the Software Assurance Reference Dataset (SARD). Moreover, it has 56395 and 364232 vulnerable and clean samples. The SeVC dataset is divided into four major categories based on the cause of the vulnerability in the following way:

- (1) **Library/API Function Call:** This category has vulnerabilities related to library/API function calls.

```

static char * badSource(char * data)
{
    data = (char *)malloc(50*sizeof(char));
    data[0] = '\0';
    return data;
}

static void bad()
{
    char * data;
    data = NULL;
    data = badSource(data);
    {
        char source[100];
        memset(source, 'C', 100-1);
        source[100-1] = '\0';
        strcat(data, source); /* Bad */
        printf(data);
        free(data);
    }
}

static char * goodSource(char * data)
{
    data = (char *)malloc(100*sizeof(char));
    data[0] = '\0';
    return data;
}

static void good()
{
    char * data;
    data = NULL;
    data = goodSource(data);
    {
        char source[100];
        memset(source, 'C', 100-1);
        source[100-1] = '\0';
        strcat(data, source); /* OK */
        printf(data);
        free(data);
    }
}

```

(a) Vulnerable with Buffer Error (b) Non-vulnerable

Figure 6: An example of a program with Buffer Error and its corrected version.

```

static void bad()
{
    int64_t * data;
    data = NULL;

    data = new int64_t;
    *data = 5LL;
    printfLongLongLine(*data);

    /* Bad: Need to release 'data' */
    return;
}

static void good()
{
    int64_t * data;
    data = NULL;

    data = new int64_t;
    *data = 5LL;
    printfLongLongLine(*data);

    delete data; /* OK */
    return;
}

```

(a) Vulnerable with RME Error (b) Non-vulnerable

Figure 7: An example of a program with Resource Management Error (RME) and its corrected version.

- (2) Array Usage: This category has vulnerabilities related to arrays, like address transfer as a function parameter and improper array element access.
- (3) Pointer Usage: This category has vulnerabilities related to pointers, like improper use in pointer arithmetic and wrong referencing.
- (4) Arithmetic Expression: This category has vulnerabilities related to arithmetic expressions, like integer overflow.

B MODELS

B.1 Bidirectional Long Short Term Memory

Bidirectional Long Short Term Memory (BiLSTM) are recurrent neural networks. It has two long short-term memory (LSTMs) [14] – one LSTM takes the input in the forward direction and the other in the backward direction – which enables BiLSTM to learn long-term dependencies in the input sequence efficiently. BiLSTM architecture is depicted in Figure 8. The LSTM block in the BiLSTM has the cell state regulated by three gates, namely forget gate, update gate, and output gate. Each LSTM cell has three inputs: (i) memory component C_{t-1} and activation component a_{t-1} are the two inputs from the previous cell, and (ii) word embedding x_t at time t of input data. Computations are carried out as presented in the following:

$$\text{Forget gate: } f_t = \sigma(W_f \cdot [a_{t-1}, x_t] + b_f),$$

$$\text{Update gate: } i_t = \sigma(W_u \cdot [a_{t-1}, x_t] + b_u),$$

$$\text{Output gate: } o_t = \sigma(W_o \cdot [a_{t-1}, x_t] + b_o),$$

where b is the bias, W is the learning parameter (weight matrix), and σ is the Sigmoid function. The memory component C_t is calculated as: $C_t = f_t * C_{t-1} + i_t * \tilde{C}_t$, where $\tilde{C}_t = \tanh(W_c[a_{t-1}, x_t] + b_c)$, and

$*$ is elementwise multiplication. The activation component for the next cell is calculated as: $a_t = o_t * \tanh(C_t)$.

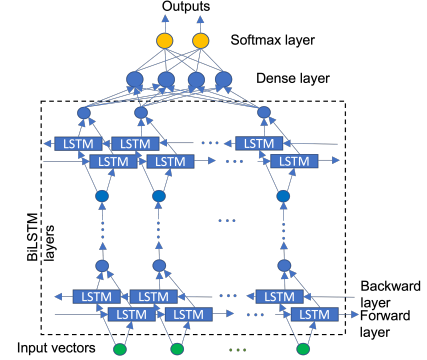


Figure 8: BiLSTM architecture.

B.2 Bidirectional Gated Recurrent Unit

Bidirectional Gated Recurrent Unit (BiGRU) [3] is a recurrent neural network with gated recurrent units (GRUs). A GRU has a gating mechanism, and it is similar to LSTM but has a forget gate, fewer parameters, and no output gate. The architecture of BiGRU is the same as in Figure 8 where each LSTM cell is replaced by a GRU cell. Moreover, each GRU cell has two inputs; memory component C_{t-1} from the previous cell and word embedding x_t at time t of input data. Computations are carried out as follows:

$$\text{Update gate: } i_t = \sigma(W_u \cdot x_t + U_u \cdot C_{t-1} + b_u),$$

$$\text{Reset gate: } r_t = \sigma(W_r \cdot x_t + U_r \cdot C_{t-1} + b_r),$$

$$\text{Current memory content: } \tilde{C}_t = \phi(W_h \cdot x_t + U_h(r_t \odot C_{t-1}) + b_h),$$

$$\text{Final memory content: } C_t = i_t \odot C_{t-1} + (1 - i_t) \odot \tilde{C}_t,$$

where b is the bias, W and U are the learning parameter (weight matrix), σ is the Sigmoid function, ϕ is a hyperbolic tangent function, and $\odot$ is the Hadamard (element-wise) product.

B.3 Transformers

Transformers are deep neural network-based models based on an attention mechanism that differentially weights the importance and context of each token in the input sentence [35]. Refer to Figure 9 for an illustration of transformer architecture. Its network architecture has encoder and decoder blocks, and the core elements in these blocks are positional encoding, multi-head attention, and fully connected layers.

Positional encoding provides the relative or exact position of the tokens (of data points) in the input sequence, and it is applied to the embeddings, which convert the input tokens (encoder block) and output tokens (decoder block) to vectors of dimension d_{model} . Sinusoidal functions can be used for the positional encodings, for example, $\sin(pos/10000^{2i/d_{\text{model}}})$ for even positions, and $\cos(pos/10000^{2i/d_{\text{model}}})$ for odd positions, where i and pos are the dimension and position index, respectively. An attention mechanism is applied to represent the input sequence by relating each word/token to related words/tokens in the input sequence. This

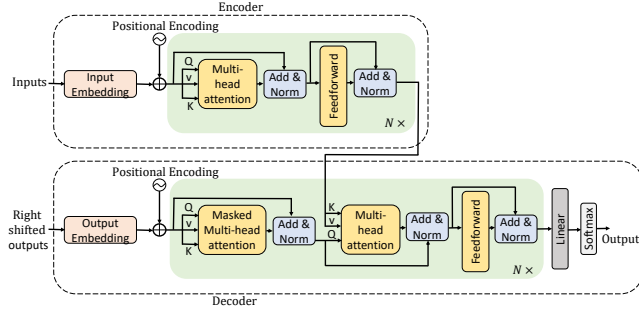


Figure 9: Transformer architecture.

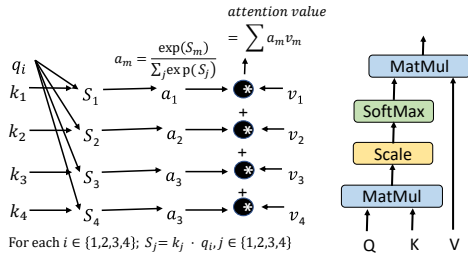


Figure 10: Illustration of operations in self-attention; scaled dot-product attention with four keys and four values associated with four tokens in an input sequence (left figure) and its system block (right figure).

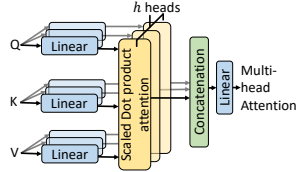


Figure 11: Multi-head attention mechanism.

is called *self-attention*. One of its examples is scaled dot-product attention, whose calculation is illustrated in Figure 10. Firstly, each output vector of the positional encoding is converted to three vectors; a query q , a key k , and a value v . The conversion is performed by multiplying the output vector by matrices W^Q , W^K , and W^V , respectively. These matrices are continuously updated during training for better projections. Secondly, the dot products of query (a vector q) with all keys (all vectors k) of the input sequence generates scores S_i , $i \in \{1, 2, 3, \dots\}$. The scores are normalized, and then softmax is calculated. This provides the weight of other parts of the input sequence while encoding a word at a specific position. Finally, each value vector is multiplied by their corresponding softmax scores and summed together to yield the attention value of the token. The following equation represents all these operations

in matrix form:

$$\text{Attention}(Q, K, V) = \text{softmax}\left(\frac{QK^T}{\sqrt{d_k}}\right)V, \quad (1)$$

where d_k is the key vector's dimension, and Q, K and V are matrices packed with all (multi-head) queries, (multi-head) keys and (multi-head) values, respectively.

The output of the attention function is further improved by collectively attending to the information from different representation subspaces. This is called *multi-head attention*, and performed as follows: (i) The queries, values, and keys are linearly projected to h times, (ii) the attention function is calculated in each projection in parallel, and (iii) all the outputs of the attention functions are concatenated and projected through the linear layer as shown in Figure 11. Its representation in matrix form is the following:

$$\text{MultiHead}(Q, K, V) = \text{Concat}(\text{head}_1, \dots, \text{head}_h)W^O, \quad (2)$$

where $\text{head}_i = \text{Attention}(QW_i^Q, KW_i^K, VW_i^V)$, and W^O is a weight matrix.

In transformer architecture, unlike in encoder block, the decoder block has two layers of multi-head attention. The first one is masked multi-head attention that enables target sequences, *i.e.*, its right-shifted previous outputs, paying attention to itself, and ignoring the future decoder's input. Next is the multi-head attention that enables the target sequence to pay attention to the input sequences. Consequently, the attention scores of each target sequence, considering the attention scores of the input sequence (coming from the encoder block), are generated, and these are transformed from their embedding space to probability space by the final fully connected layer and softmax layer.

Now we present various transformer-based models that are considered in this paper in the following paragraphs.

Bidirectional Encoder Representations from Transformers. Bidirectional Encoder Representations from Transformers (BERT) is a transformer [35] whose architecture is solely based only on its encoder blocks [5]. It scans the entire surrounding context of its input all at once, processes it through encoder blocks, and collectively fuses the left and right context in all of its layers to learn syntactic information and acquires some semantic and world knowledge [29]. It is a state-of-art language model. In this project, we have utilised two BERT models pre-trained on lower-cased English datasets such as Wikipedia (2500M words) and BooksCorpus dataset (800M words) [43]. The BERT Base model has 110M parameters with 12 layers, 768 hidden size, and 12 attention heads. The BERT Large model has 340M parameters with 24 layers, 1024 hidden size, 16 attention heads.

DistilBERT. DistilBERT [31] is a smaller, faster, cheaper, and lighter version of BERT while retaining the close performance (e.g., 95%) of the original BERT's performance. The size of DistilBERT is 40% smaller than BERT, and it is obtained by leveraging the knowledge distillation technique in the pre-training phase. Knowledge distillation is a compression technique where a smaller model, called student, is trained such that it reproduces the learning of the larger model, called teacher. DistilBERT has 66M parameters with 6 layers, 768 hidden size, and 12 attention heads.

RoBERTa. Robustly optimized BERT approach (RoBERTa) [24] updates the key hyper-parameters during BERT’s pre-training towards better optimization, performance, and robustness across NLP tasks. The updates include (1) longer model training time with more data and large mini-batch, (2) training on a longer sequence, (3) removing the next sentence prediction (an objective method applied for the BERT’s pre-training to predict if the two segments are following each other or belong to different documents to create a semantic inference), and (4) dynamic masking to the training data. This paper considers the RoBERTa with the BERT Base architecture, and it has *12 layers, 768 hidden size, and 12 attention heads*.

CodeBERT. CodeBERT [8] is a bimodal pre-trained transformer model for both programming and natural languages. It is trained on bimodal data (code & documents) [16], with codes from Python, Java, JavaScript, Ruby, Go, and PHP. Its architecture follows BERT [5] and RoBERTa [24]. During pre-training, its architecture has two generators, namely NL-generator and Code-generator, and one NL-code discriminator. NL-generator and Code-generator generate plausible tokens for masked positions based on surrounding contexts for natural language input and code input, respectively. NL-Code discriminator is trained on the tokens sampled from NL-generator and Code-generator. Its architecture is the same as RoBERTa, and it is the targeted model used for fine-tuning. Moreover, it has 125M parameters with *12 layers, 768 hidden size, and 12 attention heads*.

Generative Pre-trained Transformer. The architecture of Generative Pre-trained Transformer (GPT) is based on decoder blocks of transformer and masked self-attention [27]. GPT learns long-range dependencies between words and sentence and world knowledge through the generative pre-training, which is unsupervised learning, and this learning are transferred to specific task through fine-tuning, which is supervised learning. In contrast to BERT, GPT outputs one token at a time, and that is added to its input sequence for the next round. Consequently, each token in the input sentence has a context of the previous words only. Thus, GPT is called an auto-regressive model. GPT outperforms available models that are based on recursive neural networks, convolutional neural networks, and LSTMs [27]. Moreover, the GPT model is a powerful predictor of the next token in a sequence, so it is popular in text generation tasks. GPT models have been improved by increasing their model parameters and rigorous pre-training on a large corpus of English text datasets, called WebText [28]. More precisely, improved GPT models consider task conditioning that enables the model to produce task-specific outputs for the same input. In this paper, we consider GPT-2 models of various sizes: (1) GPT-2 Base, which has 117M parameters with *12 layers, 768 hidden size, and 12 attention heads*, (2) GPT-2 Large, which has 774M parameters with *36 layers, 1280 hidden size, and 20 attention heads*, (3) GPT-2 XL, which has 1.5B parameters with *48 layers, 1600 hidden size, and 25 attention heads*, and (4) GPT-J, which has 6B parameters with *28 layers, 4096 hidden size, and 16 attention heads*, pre-trained on the dataset called Pile having a diverse text data [10].

Megatron-LM. Megatron-LMs are transformer-based models developed by NVIDIA. They are generated by enabling intra-layer model-parallelism on the architecture level of the existing language

models, such as BERT and GPT-2 [32]. The model parallelism includes two-dimensional model parallelism: tensor model parallelism and pipeline model parallelism. The tensor model parallelism splits a single transformer across multiple GPUs, while the pipeline model parallelism splits transformer layers across multiple GPUs. Thus, these models efficiently utilize multiple GPU environments to train large models that can not be fitted inside one GPU. The resulting models do not require changes in compilers and libraries, and they enable an efficient way to scale up their model parameters to billions (e.g., 8.3B) for an increased performance [32]. Moreover, Megatron’s BERT version has rearranged normalization layers and residual connections to allow the direct flow of gradients through the network without going through the normalization layers. This enables increasing in its performance with the increase in the model’s size. In this paper, we consider Megatron versions of BERT and GPT-2 models provided by Nvidia; (1) MegatronBERT having 345M parameters with *24 layers, 1024 hidden size, and 16 attention heads*, and (2) Megatron-GPT2 having 345M parameters with *24 layers, 1024 hidden size, and 16 attention heads*. These models are pre-trained on text data sourced from Wikipedia, RealNews, OpenWebText, and CC-Stories [32].

C PERFORMANCE METRICS

Before defining the evaluation metrics presented in this paper, we define the following terms, where the positive class samples refer to vulnerable code gadgets and the negative class samples refer to non-vulnerable code gadgets: (1) True Positive (TP) is the number of the positive class samples that are correctly classified, (2) False Positive (FP) is the number of the negative class samples that are misclassified as the positive class, (3) True Negative (TN) is the number of the negative class samples that are correctly classified, and (4) False Negative (FN) is the number of the positive class samples that are misclassified as the negative class.

False Positive Rate: False Positive Rate (FPR) specifies the proportion of the negative class (i.e., non-vulnerable code gadgets) misclassified as a positive class (i.e., vulnerable code gadgets) and calculated as

$$FPR = \frac{FP}{FP + TN}.$$

False Negative Rate: False Negative Rate (FNR) specifies the proportion of the positive class (i.e., vulnerable code gadgets) misclassified as a negative class (i.e., non-vulnerable code gadgets) and calculated as

$$FNR = \frac{FN}{FN + TP}.$$

Precision: Precision specifies the classifier’s resistance to misclassifying negative class samples to positive class and calculated as

$$\text{Precision} = \frac{TP}{TP + FP}.$$

Recall: Recall specifies the classifier’s ability to correctly classify a positive class, and is calculated as

$$\text{Recall} = \frac{TP}{TP + FN}.$$

F1-score: F1-score considers FP and FN together, and it is a harmonic mean of Precision and Recall. It is calculated as

$$F1\text{-score} = 2 \times \frac{\text{Precision} \times \text{Recall}}{\text{Precision} + \text{Recall}}.$$

Table 14: Test performance of various models for the binary classification on clean VulDeePecker dataset.

Dataset and Vulnerability	Metrics	VulDeePecker Original	BiLSTM			BiGRU			BERT Base			GPT-2 Base			CodeBERT			DistilBERT		
			Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3
Group 1, Buffer Error (BE)	FPR	2.90%	33.25%	36.36%	31.98%	18.41%	11.64%	15.52%	4.80%	3.16%	4.20%	4.11%	3.82%	4.68%	2.89%	2.45%	3.58%	3.70%	3.99%	3.87%
	FNR	18.00%	17.61%	10.85%	17.37%	31.54%	39.34%	35.58%	6.90%	5.71%	6.95%	6.11%	6.98%	6.23%	4.47%	4.70%	5.37%	6.77%	6.15%	7.34%
	Precision	82.00%	71.25%	71.03%	72.10%	69.70%	77.35%	72.07%	92.31%	95.13%	93.24%	93.40%	94.09%	92.56%	95.34%	96.22%	94.26%	93.97%	93.90%	93.70%
	Recall	91.70%	82.39%	89.15%	82.63%	68.46%	60.66%	64.42%	93.10%	94.29%	93.05%	93.89%	93.02%	93.77%	95.53%	95.30%	94.63%	93.23%	93.85%	92.66%
	F1-score	86.60%	76.42%	79.07%	77.01%	69.08%	67.99%	68.03%	92.71%	94.71%	93.15%	93.64%	93.55%	93.16%	95.44%	95.76%	94.44%	93.60%	93.87%	93.18%
Group 2, Resource Management Error (RME)	FPR	2.80%	16.79%	18.18%	13.33%	4.13%	3.35%	5.73%	3.05%	4.04%	2.86%	4.33%	3.75%	3.36%	3.24%	3.45%	2.57%	4.82%	5.03%	3.36%
	FNR	4.70%	11.94%	9.46%	16.48%	10.45%	11.87%	8.70%	6.34%	4.82%	6.30%	5.04%	3.90%	6.11%	5.60%	3.53%	5.00%	6.53%	6.68%	8.15%
	Precision	95.30%	83.99%	83.28%	86.23%	91.95%	93.32%	89.47%	94.18%	92.60%	94.58%	92.04%	93.17%	93.72%	93.88%	93.69%	95.18%	91.09%	90.79%	93.58%
	Recall	94.60%	88.06%	90.54%	83.52%	89.55%	88.13%	91.30%	93.66%	95.18%	93.70%	94.96%	96.10%	93.89%	94.40%	96.47%	95.00%	93.47%	93.32%	91.85%
	F1-score	95.00%	85.97%	86.76%	84.85%	90.74%	90.65%	90.38%	93.92%	93.87%	94.14%	93.48%	94.61%	93.80%	94.14%	95.06%	95.09%	92.27%	92.04%	92.71%

Table 15: Test performance of various models for the binary classification on clean VulDeePecker dataset.

Dataset and Vulnerability	Metrics	RoBERTa			GPT-2 Large			GPT-2 XL			MegatronBERT			MegatronGPT2			GPT-J		
		Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3
Group 1, Buffer Error (BE)	FPR	3.98%	4.41%	5.05%	2.72%	2.12%	3.18%	2.76%	2.33%	2.89%	3.41%	2.83%	3.50%	2.97%	2.58%	2.89%	3.66%	2.49%	2.08%
	FNR	5.65%	8.25%	5.77%	4.66%	4.63%	4.85%	4.99%	4.51%	5.31%	4.86%	4.82%	6.03%	5.39%	5.08%	6.36%	3.61%	5.33%	8.32%
	Precision	93.61%	93.17%	92.06%	95.59%	96.72%	94.90%	95.51%	96.41%	95.32%	94.52%	95.66%	94.34%	95.18%	96.02%	95.27%	94.22%	96.13%	96.48%
	Recall	94.35%	91.75%	94.23%	95.34%	95.37%	95.15%	95.01%	95.49%	94.69%	95.14%	95.18%	93.97%	94.61%	94.92%	93.64%	96.39%	94.67%	91.68%
	F1-score	93.98%	92.46%	93.13%	95.46%	96.04%	95.03%	95.26%	95.95%	95.00%	94.83%	95.42%	94.16%	94.89%	95.47%	94.45%	95.29%	95.40%	94.02%
Group 2, Resource Management Error (RME)	FPR	3.34%	3.16%	2.27%	2.16%	1.18%	1.78%	2.16%	1.58%	1.58%	3.15%	2.27%	1.78%	2.75%	1.97%	2.76%	2.16%	1.08%	3.26%
	FNR	5.60%	4.45%	5.56%	3.36%	2.78%	3.15%	2.80%	3.15%	3.89%	2.80%	4.08%	3.70%	2.43%	3.34%	3.33%	3.73%	5.19%	2.96%
	Precision	93.70%	94.15%	95.68%	95.93%	97.76%	96.67%	95.95%	97.03%	97.01%	94.21%	95.74%	96.65%	94.92%	96.30%	94.91%	95.91%	97.89%	94.08%
	Recall	94.40%	95.55%	94.44%	96.64%	97.22%	96.85%	97.20%	96.85%	96.11%	97.20%	95.92%	96.30%	97.57%	96.66%	96.67%	96.27%	94.81%	97.04%
	F1-score	94.05%	94.84%	95.06%	96.28%	97.49%	96.76%	96.57%	96.94%	96.56%	95.68%	95.83%	96.47%	96.23%	96.48%	95.78%	96.09%	96.32%	95.53%

Table 16: Test performance of various models for the multi-class classification on clean VulDeePecker dataset.

Dataset and Vulnerability	Metrics	VulDeePecker Original	BiLSTM			BiGRU			BERTBase			GPT-2 Base			CodeBERT			DistilBERT		
			Fold1	Fold 2	Fold 3	Fold1	Fold 2	Fold 3	Fold1	Fold 2	Fold 3	Fold1	Fold 2	Fold 3	Fold1	Fold 2	Fold 3	Fold1	Fold 2	Fold 3
Group 3, Buffer Error (BE)	FPR	2.90%	21.19%	20.80%	21.89%	11.96%	4.97%	4.16%	2.23%	2.59%	2.30%	2.58%	3.30%	2.98%	1.65%	2.08%	2.00%	2.00%	2.69%	2.58%
	FNR	18.00%	12.89%	15.49%	13.45%	26.18%	43.56%	46.19%	5.20%	4.83%	4.53%	5.39%	5.65%	5.18%	5.46%	5.02%	4.00%	6.97%	5.33%	5.18%
	Precision	82.00%	60.99%	61.88%	60.15%	70.13%	81.94%	83.16%	94.18%	93.63%	94.05%	93.32%	91.96%	92.39%	95.61%	94.80%	94.82%	94.65%	93.36%	93.35%
	Recall	91.70%	87.11%	84.51%	86.55%	73.82%	56.44%	53.81%	94.80%	95.17%	95.47%	94.61%	94.35%	94.82%	94.54%	94.98%	96.00%	93.03%	94.67%	94.82%
	F1-score	86.60%	71.74%	71.44%	70.97%	71.92%	66.84%	65.34%	94.49%	94.40%	94.76%	93.96%	93.14%	93.59%	95.07%	94.89%	95.40%	93.83%	94.01%	94.08%
Group 3, Resource Management Error (RME)	FPR	2.80%	3.20%	3.18%	3.84%	0.80%	0.48%	0.69%	0.78%	0.56%	0.65%	1.02%	0.97%	1.07%	0.62%	0.64%	0.65%	0.72%	0.68%	0.79%
	FNR	4.70%	11.65%	12.59%	7.82%	5.55%	8.21%	8.70%	4.25%	4.93%	3.02%	5.18%	5.47%	3.37%	4.07%	4.74%	3.55%	4.44%	5.84%	3.37%
	Precision	95.30%	75.04%	75.20%	73.20%	92.74%	95.45%	93.80%	93.00%	94.90%	94.46%	90.96%	91.52%	91.12%	94.36%	94.22%	94.43%	93.49%	93.82%	93.31%
	Recall	94.60%	88.35%	87.41%	92.18%	94.45%	91.79%	91.30%	95.75%	95.07%	96.98%	94.82%	94.53%	96.63%	95.93%	95.26%	96.45%	95.56%	94.16%	96.63%
	F1-score	95.00%	81.15%	80.84%	81.60%	93.59%	93.58%	92.53%	94.35%	94.99%	95.71%	92.85%	93.00%	93.79%	95.14%	94.74%	95.43%	94.52%	93.99%	94.94%
Group 3, BE + RME (Global Avg.)	Precision	N/A	64.17%	64.92%	63.34%	75.92%	86.35%	86.96%	93.87%	93.95%	94.16%	92.68%	91.84%	92.04%	95.28%	94.65%	94.71%	94.33%	93.48%	93.34%
	Recall	N/A	87.43%	85.26%	88.07%	79.23%	65.57%	63.92%	95.05%	95.15%	95.88%	94.66%	94.39%	95.30%	94.91%	95.05%	96.12%	93.69%	94.54%	95.30%
	F1-score	N/A	74.02%	73.71%	73.68%	77.54%	74.54%	73.68%	94.46%	94.55%	95.01%	93.66%	93.10%	93.64%	95.09%	94.85%	95.41%	94.01%	94.00%	94.31%
Group 3, BE + RME (Macro Avg.)	Precision	88.65%	68.01%	68.54%	66.67%	81.43%	88.69%	88.48%	93.59%	94.26%	94.26%	92.14%	91.74%	91.76%	94.99%	94.51%	94.63%	94.07%	93.59%	93.33%
	Recall	93.15%	87.73%	85.96%	89.37%	84.14%	74.12%	72.55%	95.28%	95.12%	96.23%	94.71%	94.44%	95.72%	95.24%	95.12%	96.22%	94.30%	94.41%	95.72%
	F1-score	90.80%	76.62%	76.27%	76.37%	82.76%	80.75%	79.73%	94.43%	94.69%	95.23%	93.41%	93.07%	93.70%	95.11%	94.82%	95.42%	94.18%	94.00%	94.51%

Table 17: Test performance of various models for the multi-class classification on clean VulDeePecker dataset.

Dataset and Vulnerability	Metrics	RoBERTa			GPT-2 Large			GPT-2 XL			MegatronBERT			MegatronGPT-2			GPT-J		
		Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3	Fold 1	Fold 2	Fold 3
Group 3, Buffer Error (BE)	FPR	2.15%	2.54%	2.53%	1.50%	1.78%	1.53%	1.50%	1.50%	1.40%	1.90%	1.78%	1.80%	1.80%	2.31%	1.98%	1.60%	1.47%	1.25%
	FNR	5.66%	6.54%	4.86%	5.13%	4.38%	5.38%	4.80%	4.57%	4.92%	5.20%	4.76%	3.87%	5.33%	5.52%	4.40%	5.00%	4.83%	5.84%
	Precision	94.34%	93.64%	93.49%	96.01%	95.56%	95.94%	96.02%	96.22%	96.28%	94.99%	95.54%	95.32%	95.23%	94.24%	94.86%	95.76%	96.27%	96.63%
	Recall	94.34%	93.46%	95.14%	94.87%	95.62%	94.62%	95.20%	95.43%	95.08%	94.80%	95.24%	96.13%	94.67%	94.48%	95.60%	95.00%	95.17%	94.16%
	F1-score	94.34%	93.55%	94.31%	95.43%	95.59%	95.28%	95.61%	95.82%	95.68%	94.90%	95.39%	95.72%	94.95%	94.36%	95.23%	95.38%	95.72%	95.38%
Group 3, Resource Management Error (RME)	FPR	0.88%	0.62%	0.75%	0.40%	0.36%	0.50%	0.44%	0.38%	0.42%	0.46%	0.42%	0.63%	0.58%	0.46%	0.65%	0.22%	0.22%	0.30%
	FNR	4.99%	4.01%	3.20%	3.70%	2.55%	2.31%	3.70%	3.28%	2.31%	4.25%	4.01%	2.66%	2.77%	4.01%	3.02%	5.18%	7.30%	5.15%
	Precision	92.11%	94.43%	93.64%	96.30%	96.74%	95.65%	95.95%	96.54%	96.32%	95.75%	96.16%	94.65%	94.77%	95.81%	94.46%	97.90%	97.88%	97.27%
	Recall	95.01%	95.99%	96.80%	96.30%	97.45%	97.69%	96.30%	96.72%	97.69%	95.75%	95.99%	97.34%	97.23%	95.99%	96.98%	94.82%	92.70%	94.85%
	F1-score	93.54%	95.20%	95.20%	96.30%	97.09%	96.66%	96.13%	96.63%	97.00%	95.75%	96.07%	95.97%	95.99%	95.90%	95.71%	96.34%	95.22%	96.04%
Group 3, BE + RME (Global Avg.)	Precision	93.74%	93.85%	93.53%	96.08%	95.86%	96.00%	96.31%	96.29%	95.19%	95.70%	95.13%	95.11%	94.64%	94.75%	96.31%	96.68%	96.80%	
	Recall	94.52%	94.11%	95.59%	95.25%	96.09%	95.45%	95.49%	95.76%	95.78%	95.05%	95.43%	96.45%	95.34%	94.87%	95.98%	94.95%	94.54%	94.35%
	F1-score	94.13%	93.98%	94.55%	95.66%	95.98%	95.65%	95.74%	96.03%	96.04%	95.12%	95.57%	95.79%	95.23%	94.75%	95.36%	95.63%	95.59%	95.56%
Group 3, BE + RME (Macro Avg.)	Precision	93.23%	94.04%	93.57%	96.15%	95.80%	95.98%	96.38%	96.30%	95.37%	95.85%	94.98%	95.00%	95.02%	94.75%	94.66%	96.83%	97.08%	